QUY TRÌNH PHÁT TRIỂN PHẦN MỀM TÍCH HỢP AI (AI-SDLC)

Phiên bản 5.9

Nền tảng tham chiếu: Spec-Driven Development (GitHub Spec Kit) + Agile/Scrum + DevOps, bổ sung AI gate và Human gate.

Phạm vi áp dụng: Mọi dự án phần mềm của công ty (task nhỏ < 0,5 ngày công có thể đi luồng rút gọn — xem mục 6).

Nhật ký thay đổi (Changelog)

Phiên bản	Nội dung thay đổi chính
5.0	Bản gốc — 14 bước, 5 giai đoạn, RACI rút gọn, 4 phụ lục biểu mẫu.
5.1	Bổ sung: RACI đầy đủ 14 bước với 7 vai trò (thêm PO/Sponsor, Security, DevOps/Ops); tách rõ 3 sign-off trong Gate 4 (SIT/Regression, ATTT, Hiệu năng); chuẩn hóa Defect Management (bảng Severity/Priority/SLA, vòng đời bug, quy trình hotfix); luật thăng cấp môi trường (build-once-promote-many, IaC); Hypercare & Go/No-Go meeting; quản trị AI tool & bản quyền code AI; thống nhất thuật ngữ Tầng 2 skill.md; kiểm duyệt skill.md đối tác chống prompt injection; 2 phụ lục mới (Bug Report, UAT Sign-off & Go/No-Go Checklist); sửa lỗi tham chiếu chéo.
5.2	Đào sâu B2 (Constitution & skill.md): mở rộng nhóm rules/ (thêm adr-rules, api-rules, test-rules, code-review-rules); bổ sung 6 tài liệu mới (glossary.md, dor-dod.md, data-classification.md, ai-tool-scope.md, tool-permissions.md, adr-template.md) + file chỉ mục docs-index.md; cập nhật thực tế công cụ 2026 (chuẩn liên-công-cụ AGENTS.md, rủi ro prompt injection qua file cấu hình agent). Thêm Phụ lục 7 — Bộ biểu mẫu chi tiết cho B2.
5.3	Bổ sung mục "Hướng dẫn thực hiện" (quy trình từng bước, ai làm gì theo đúng thứ tự) cho toàn bộ 14 bước B1–B14, làm rõ trình tự bàn giao giữa PM/BA/Dev/Tech Lead/Test/Security/DevOps/PO và AI tại mỗi bước.
5.4	Gộp Phụ lục 3 và Phụ lục 7 (V5.2) thành một Phụ lục 3 duy nhất, đầy đủ 17 file theo đúng 4 nhóm + 1 nhóm file chỉ mục đã mô tả ở B2 (trước đây chỉ có 6/17 file, phần còn lại tách rời ở Phụ lục 7 gây khó tra cứu). Cập nhật các tham chiếu chéo từ "Phụ lục 7" sang "Phụ lục 3".
5.5	Mở rộng chi tiết cả 17 mục trong Phụ lục 3: mỗi mục có thêm phần "Cách dựng" (ai dựng, dựa trên chuẩn nào, quy trình nạp vào AI agent) và nội dung mẫu đầy đủ hơn — đặc biệt constitution.md (theo đúng cấu trúc /speckit.constitution của GitHub Spec Kit: Metadata, Core Principles với Rule/Rationale/Application, Governance), CODING_CONVENTION.md (bảng naming, formatting, cây thư mục, ví dụ docstring), SKILL.md (7 phần: Identity, thứ tự đọc file, phạm vi quyền hạn, xử lý khi không chắc chắn, workflow coding, Tầng 1/Tầng 2), và prompts.md (bổ sung prompt cho B9/B10/B13).
5.6	Mở rộng Phụ lục 4 (đổi tên thành "Bộ biểu mẫu cho bước B3"): trước đây chỉ có mẫu BRD sơ sài, nay bổ sung đầy đủ cả 3 tài liệu đầu ra của B3 — Biên bản họp/Workshop (mới, có phân biệt phát biểu gốc vs AI diễn giải), BRD nâng cấp theo BABOK v3 (User Story chuẩn, MoSCoW, yêu cầu phi chức năng định lượng được), và Process Flow/User Journey (mới, theo ký hiệu BPMN 2.0, mẫu bảng As-is/To-be, User Journey Map rút gọn).
5.7	Vẽ lưu đồ chuẩn cho B3 (oval/chữ nhật/hình thoi) kèm bảng chi tiết Người thực hiện/Cách thức thực hiện/Lưu ý/Biểu mẫu sử dụng cho từng bước. Phát hiện & bổ sung 2 mẫu còn thiếu mà lưu đồ có nhắc tới: 4.1 Hướng dẫn phỏng vấn/Interview Guide (mới, dùng ở bước 1) và 4.5 Q&A Log (mới, dùng khi xử lý xung đột ý kiến giữa stakeholder — cũng dùng xuyên suốt tới B5). Đánh số lại Phụ lục 4 thành 5 mục (4.1–4.5).
5.8	Nhúng lưu đồ chuẩn B3 (dạng ảnh) và bảng chi tiết 5 cột (Bước/Người thực hiện/Cách thức thực hiện/Lưu ý/Biểu mẫu sử dụng) trực tiếp vào mục 2, B3, thay cho danh sách "Hướng dẫn thực hiện" ngắn gọn trước đây — là bước B đầu tiên có lưu đồ trực quan trong tài liệu.
5.9	Áp dụng lưu đồ + bảng 5 cột cho toàn bộ 13 bước còn lại (B1, B2, B4–B14) — mỗi bước giờ có lưu đồ trực quan (oval/chữ nhật, tô màu vàng riêng cho các bước Human Gate) và bảng chi tiết Cách thức thực hiện/Biểu mẫu sử dụng. Rà soát phát hiện 9 tài liệu đầu ra hiện CHƯA có biểu mẫu chuẩn trong phụ lục: User Story/AC (B4), Biên bản duyệt Spec (B5), plan.md/C4 Model (B6), tasks.md (B7), checklist Human Review riêng

	(B10, khác với rules/code-review-rules.md

Phiên bản	Nội dung thay đổi chính
	dùng cho AI), Test Plan/Test Case (B11), Rollback Plan (B13), Runbook (B14), Post-mortem (B14) — đã đánh dấu rõ trong bảng để bổ sung ở bản kế tiếp.

1. TỔNG QUAN 14 BƯỚC — 5 GIAI ĐOẠN

Giai đoạn	Bước	Tên bước	Human Gate
GĐ 0. Khởi tạo	B1	Project Charter & Kick-off	PM duyệt
	B2	Constitution & skill.md (luật của dự án)	Tech Lead + PM duyệt
GĐ 1. Yêu cầu	B3	Thu thập & phân tích yêu cầu	—
	B4	Viết Spec (Specify)	—
	B5	Làm rõ & chốt Spec (Clarify)	⛔ Gate 1: PO/PM ký duyệt Spec
GĐ 2. Thiết kế	B6	Technical Plan & Kiến trúc	⛔ Gate 2: Tech Lead duyệt kiến trúc
	B7	Phân rã Task & lập kế hoạch sprint	PM duyệt sprint backlog
GĐ 3. Lập trình	B8	Coding (AI-assisted / agentic)	—
	B9	Unit Test	Coverage gate tự động
	B10	Code Review (2 tầng: AI → Người)	⛔ Gate 3: Human approve mới được merge
GĐ 4. Kiểm thử	B11	Test Plan & Test Case	Test Lead duyệt
	B12	SIT / Regression / UAT / ATTT & Hiệu năng	⛔ Gate 4a/4b/4c + Gate 4: xem mục 2, B12
GĐ 5. Phát hành & Vận hành	B13	Release & Triển khai môi trường	⛔ Gate 5: Go/No-Go go-live
	B14	Vận hành, giám sát & cải tiến	Post-mortem có người chủ trì

2. CHI TIẾT TỪNG BƯỚC: TÀI LIỆU — CHUẨN — CÔNG CỤ AI

GIAI ĐOẠN 0 — KHỞI TẠO DỰ ÁN

B1. Project Charter & Kick-off

- **Tài liệu đầu ra:** Project Charter, Stakeholder Register, Communication Plan.
- **Chuẩn áp dụng:** PMBOK Guide (PMI); template Charter nội bộ công ty.
- **AI khuyến nghị:** Claude/ChatGPT để draft Charter từ ghi chú họp; Fireflies/Otter.ai ghi và tóm tắt biên bản kick-off.

Lưu ý: AI chỉ draft — PM chịu trách nhiệm nội dung cuối cùng.

Lưu đồ thực hiện (bổ sung V5.9)



- **Bảng chi tiết theo từng bước:**

Bước	Người thực hiện	Cách thức thực hiện	Lưu ý	Biểu mẫu sử dụng
1. Lên lịch họp kick-off	PM	Lên lịch họp, mời Sponsor/PO và các thành viên chủ chốt; gửi agenda trước tối thiểu 1 ngày.	Thiếu người có quyền quyết định sẽ phải họp lại.	—
2. AI ghi âm & tóm tắt	AI (Fireflies/ Otter)	Ghi âm toàn bộ buổi kick-off, tự động tóm tắt thành biên bản nháp.	Xin phép người tham dự trước khi ghi âm.	—
3. Draft Charter, Stakeholder, Comm Plan	PM (dùng AI hỗ trợ)	Dùng Claude/ChatGPT draft cả 3 tài liệu từ bản tóm tắt, đúng cấu trúc mẫu.	AI chỉ draft — PM chịu trách nhiệm nội dung cuối cùng.	**Project Charter, Stakeholder Register, Comm Plan — PL 1**
4. PM rà soát & chỉnh sửa	PM	Đối chiếu thực tế ngân sách/phạm vi; sửa lại phần AI draft sai.	AI không được tự quyết định số liệu ngân sách/phạm vi.	—
5. Gửi Sponsor/PO xem trước	PM	Gửi bản draft qua email/Confluence, tổng hợp góp ý trước buổi ký.	—	—
6. Ký duyệt Charter	Sponsor/PO	Ký duyệt chính thức — điều kiện để cấp ngân sách/nhân sự.	Human Gate — không chặn kỹ thuật nhưng bắt buộc trước khi triển khai.	PL 1
7. Lưu trữ & khởi tạo dự án	PM	Lưu Charter vào Confluence/SharePoint, khởi tạo project trên Jira/Azure DevOps.	—	—

B2. Constitution & skill.md — "Luật" cho cả người và AI

Cập nhật V5.2: B2 là bước quyết định chất lượng của toàn bộ 12 bước sau — mọi lỗi hiểu domain/kiến trúc/quyền hạn AI ở B2 sẽ nhân bản ra tất cả các bước tiếp theo. Danh sách tài liệu đầu ra được mở rộng thành 4 nhóm + 1 file chỉ mục. Mẫu chi tiết (có thể copy dùng ngay) của toàn bộ các file bên dưới nằm tại Phụ lục 3.

- **Nhóm 1 — Quy định kỹ thuật:**
- **constitution.md: Quy tắc bất biến về kiến trúc, bảo mật, và logging của hệ thống.**
    - **CODING_CONVENTION.md:** Quy tắc cú pháp code, naming convention, cấu trúc folder.
    - **adr-template.md (mới V5.2):** Khuôn mẫu chuẩn cho Architecture Decision Record, dùng từ B6 trở đi để AI sinh ADR nhất quán ngay từ đầu.
- **Nhóm 2 — Quy định vận hành AI:**
    - **SKILL.md:** Mô tả "công việc" của AI Agent — nguyên tắc phân tầng 1 & 2 (xem mục 7) để AI biết nó là ai, được phép/không được phép làm gì.
    - **tool-permissions.md (mới V5.2):** Cụ thể hóa quyền hạn AI Agent thành danh sách hành động được/không được tự động thực hiện (least-privilege) — VD: được tự chạy test/lint, không được tự chạy migration DB hay push thẳng lên main.
    - **data-classification.md (mới V5.2):** Phân loại dữ liệu Public/Internal/Confidential/Restricted và quy định loại nào được phép đưa vào prompt AI.
    - **ai-tool-scope.md (mới V5.2):** Danh mục AI tool cụ thể được duyệt riêng cho dự án này (khác với danh sách chung ở mục 5), kèm trạng thái Zero Data Retention.
- **Nhóm 3 — Quy định & thư viện Prompt:**
    - **prompts.md:** Thư viện System Prompt tinh chỉnh cho từng giai đoạn (B3, B4, B6...).
- **Nhóm 4 — Quy tắc kiểm tra (rules/) — mở rộng V5.2 để phủ mọi giai đoạn AI tự sinh nội dung, không chỉ riêng BA:**
    - **rules/brd-rules.md, rules/bpm-rules.md:** Linter cho BRD/BPMN (giai đoạn B3/B4) — đã có từ V5.0.
    - **rules/adr-rules.md (mới V5.2):** Linter cho ADR — dùng ở B6.
    - **rules/api-rules.md (mới V5.2):** Linter cho OpenAPI Spec — dùng ở B6.
    - **rules/test-rules.md (mới V5.2):** Linter cho Unit Test AI sinh ra — dùng ở B9.
    - **rules/code-review-rules.md (mới V5.2):** Checklist cụ thể hóa OWASP ASVS cho AI review tầng 1 — dùng ở B10.
- **File chỉ mục (mới V5.2):**
    - **docs-index.md:** Bản đồ tổng toàn bộ tài liệu B2 (mục đích, owner, thuộc Tầng 1/Tầng 2, tần suất cập nhật) — giúp người mới và AI agent mới onboard nhanh thay vì phải tự dò hơn 10 file rải rác.
    - **glossary.md và dor-dod.md:** Xem thêm — glossary.md (Từ điển thuật ngữ nghiệp vụ) do BA làm chủ, khởi tạo khung ở B2 nhưng cập nhật liên tục từ B3; dor-dod.md (Definition of Ready/Done) chuẩn hóa tiêu chí khách quan cho mọi Gate. Mẫu cả hai tại Phụ lục 3.
- **Chuẩn áp dụng:** Spec Kit /speckit.constitution; OWASP ASVS cho yêu cầu bảo mật.
- **AI khuyến nghị:** Spec Kit CLI; Claude Code để sinh khung constitution rồi Tech Lead tinh chỉnh.

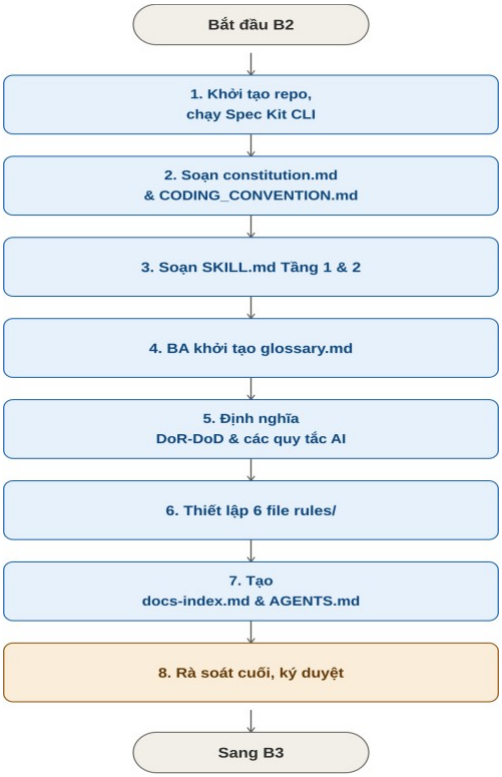
Cập nhật thực tế công cụ AI đa nền tảng (bổ sung V5.2)

Tính đến giữa 2026, ngành đã hội tụ về AGENTS.md làm chuẩn liên-công-cụ (Linux Foundation/Agentic AI Foundation), được Claude Code, GitHub Copilot, Cursor, Gemini CLI... đọc trực tiếp. Khuyến nghị: coi SKILL.md/constitution.md là nguồn chân lý duy nhất của dự án, sau đó đồng bộ/sinh ra AGENTS.md ở gốc repo — tránh tình trạng duy trì song song CLAUDE.md/.cursorrules/copilot-instructions.md dễ lệch nội dung, khiến các AI agent nhận chỉ dẫn xung đột nhau.

Rủi ro bảo mật cần lưu ý: đã ghi nhận các kỹ thuật prompt injection gián tiếp qua chính file cấu hình agent (AGENTS.md/SKILL.md). Do đó quy tắc "kiểm duyệt skill.md đối tác trước khi nạp cho AI" (mục 7) nay áp dụng cho MỌI file cấu hình agent, kể cả file do nội bộ tạo — phải qua Pull Request và Tech Lead review như code, không được chỉnh trực tiếp trên môi trường agent đang chạy.

Quy tắc bất biến: Toàn bộ tài liệu B2 nằm trong repo, versioned bằng Git; mọi thay đổi phải qua PR và Tech Lead review. Chi tiết chính sách 2 tầng công ty/dự án xem mục 7.

Lưu đồ thực hiện (bổ sung V5.9)



- **Bảng chi tiết theo từng bước:**

Bước	Người thực hiện	Cách thức thực hiện	Lưu ý	Biểu mẫu sử dụng
1. Khởi tạo repo & Spec Kit	Tech Lead	Chạy Spec Kit CLI (/speckit.constitution) để sinh khung constitution.md ban đầu.	—	—
2. Soạn constitution.md & CODING_CONVENTION.md	Tech Lead + AI	Điền đầy đủ Core Principles (Rule/Rationale/Application) dựa trên stack đã chọn ở B1.	Mỗi nguyên tắc phải đo lường được, không viết chung chung.	**PL 3.1, 3.2**
3. Soạn SKILL.md	Tech Lead	Soạn Tầng 1 theo chuẩn công ty, bổ sung Tầng 2 riêng cho dự án.	—	PL 3.4
4. Khởi tạo glossary.md	BA	Điền khung ban đầu với vài thuật ngữ cốt lõi đã biết trước.	Sẽ hoàn thiện dần từ B3, không chờ xong hết mới bắt đầu.	PL 3.16
5. Định nghĩa DoR-DoD & quy tắc AI	PM + Tech Lead	Copy mẫu dor-dod.md, tool-permissions.md, data-classification.md, ai-tool-scope.md, tùy biến theo dự án.	—	PL 3.5, 3.6, 3.7, 3.17
6. Thiết lập rules/	Tech Lead	Copy 6 file rules/ (brd, bpm, adr, api, test, code-review) từ mẫu có sẵn.	—	PL 3.9–3.14
7. Tạo docs-index.md & AGENTS.md	Tech Lead	Liệt kê toàn bộ tài liệu B2; đồng bộ SKILL.md ra AGENTS.md ở gốc repo.	—	PL 3.15
8. Rà soát & ký duyệt	Tech	Rà soát lần cuối toàn bộ tài liệu, ký duyệt, commit vào	Human Gate — quyết định chất	—
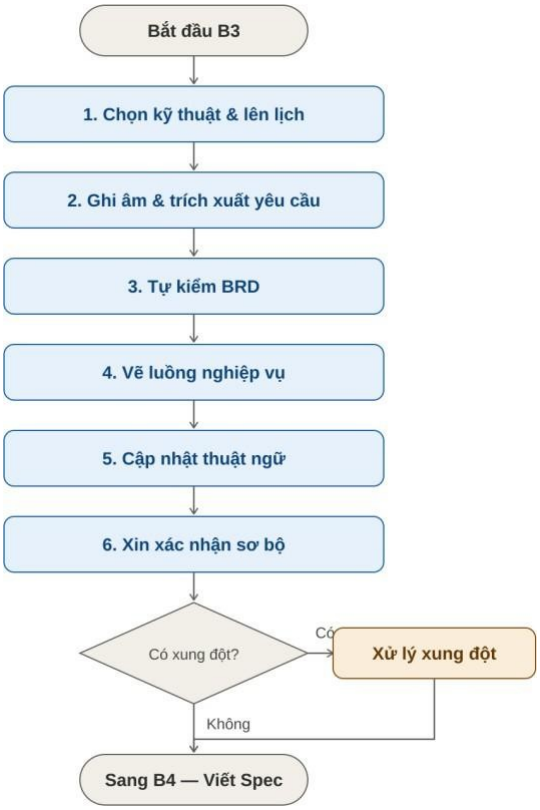
	Lead + PM	main, gắn tag v0-constitution.	lượng toàn bộ 12 bước sau.	

GIAI ĐOẠN 1 — YÊU CẦU

B3. Thu thập & phân tích yêu cầu

- **Tài liệu đầu ra:** BRD, Biên bản họp, Process flow / User journey.
- **Chuẩn áp dụng:** BABOK v3 (IIBA), BPMN 2.0.
- **AI khuyến nghị:** AI ghi họp, trích xuất yêu cầu, sinh sơ đồ BPMN nháp.

Lưu đồ thực hiện (bổ sung V5.7)



- **Bảng chi tiết theo từng bước:**

Bước	Người thực hiện	Cách thức thực hiện	Lưu ý	Biểu mẫu sử dụng
1. Chọn kỹ thuật & lên lịch	BA	Chọn kỹ thuật theo tình huống: Interview (vấn đề nhạy cảm), Workshop (nhiều stakeholder), Document Analysis (đã có tài liệu cũ), Observation, Prototyping.	Không mặc định luôn phỏng vấn — chọn đúng kỹ thuật tiết kiệm thời gian hơn nhiều.	**Hướng dẫn phỏng vấn — PL 4.1**
2. Ghi âm & trích xuất yêu cầu	AI (Fireflies/ Otter) + BA	Bật ghi âm, xin phép người tham dự trước. Sau họp lấy transcript, đưa vào prompt B3 (prompts.md) để AI trích xuất → BRD nháp.	Chỗ AI tóm tắt còn nghi ngờ, phải nghe lại đúng đoạn ghi âm gốc.	Biên bản họp — PL 4.2
3. Tự kiểm BRD	BA	Đọc từng câu hỏi trong rules/brd-rules.md, đánh dấu Đạt/Không đạt cho từng mục.	Mục nào Không đạt phải sửa BRD ngay tại chỗ, không dồn qua bước sau.	rules/brd-rules.md — PL 3.9

4. Vẽ luồng nghiệp vụ	AI (vẽ nháp) + BA (review)	Luồng >3 actor hoặc >2 điểm rẽ nhánh → bắt buộc BPMN đầy đủ theo rules/bpm-rules.md;	Không được để "nhánh cụt" — mọi Gateway	Process Flow/User Journey — PL 4.4 + rules/bpm-

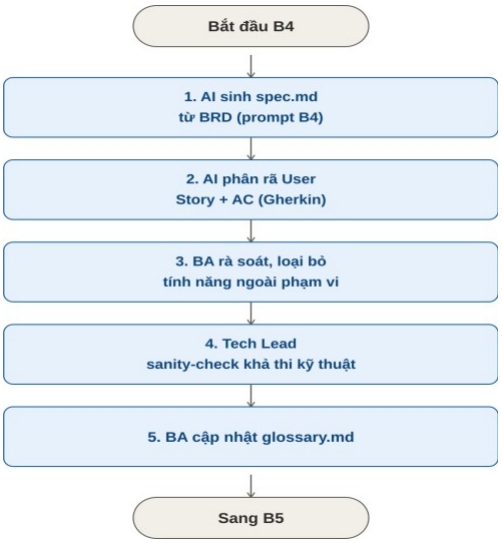
Bước	Người thực hiện	Cách thức thực hiện	Lưu ý	Biểu mẫu sử dụng
		đơn giản hơn → chỉ cần User Journey Map.	phải dẫn tới End Event hoặc hội tụ lại.	rules.md — PL 3.10
5. Cập nhật thuật ngữ	BA	Thêm vào glossary.md nếu từ: lặp lại nhiều lần, có nghĩa riêng khác thông thường, hoặc dễ nhầm với từ khác.	Cập nhật liên tục ngay trong B3, không chờ gom hết mới cập nhật 1 lần.	glossary.md — PL 3.16
6. Xin xác nhận sơ bộ	BA → PO/khách hàng	Gửi BRD qua kênh chính thức (email/Confluence), nêu rõ thời hạn phản hồi 2-3 ngày làm việc.	Đây chưa phải Human Gate chính thức — chỉ là xác nhận sơ bộ trước khi qua B4.	BRD — PL 4.3
Xử lý xung đột (nếu có)	BA	Khi 2 stakeholder nói khác nhau về cùng một quy trình, ghi nhận đầy đủ cả 2 ý kiến.	Không tự chọn bên nào đúng — đưa PO/Sponsor quyết định chính thức tại Gate 1 (B5).	**Q&A Log — PL 4.5**

B4. Viết Spec (Specify)

- **Tài liệu đầu ra:** spec.md, User Story + Acceptance Criteria, SRS.
- **Chuẩn áp dụng:** ISO/IEC/IEEE 29148, INVEST, Gherkin (Given–When–Then).

Lưu ý: chưa có biểu mẫu chuẩn riêng cho spec.md/User Story trong phụ lục — đề xuất bổ sung ở bản cập nhật kế tiếp.

Lưu đồ thực hiện (bổ sung V5.9)



- **Bảng chi tiết theo từng bước:**

Bước	Người thực hiện	Cách thức thực hiện	Lưu ý	Biểu mẫu sử dụng
1. AI sinh spec.md từ BRD	BA	Dùng prompt B4 (prompts.md), đưa BRD đã xác nhận sơ bộ cho AI sinh spec.md theo chuẩn Spec Kit.	—	prompts.md — PL 3.8

2. AI phân rã User Story + AC	AI	Phân rã theo INVEST, viết Acceptance Criteria dạng Gherkin (Given-When-Then).	—	Chưa có mẫu chuẩn
3. BA rà soát User Story	BA	Đảm bảo đúng phạm vi BRD, loại bỏ tính năng AI "tự chế" ngoài phạm vi cuộc họp.	—	—

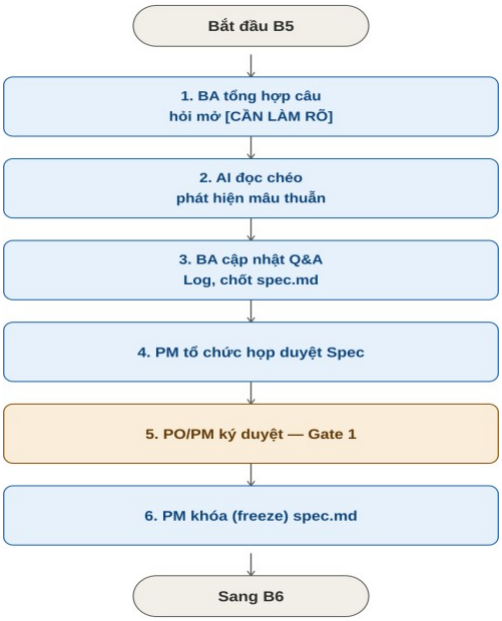
Bước	Người thực hiện	Cách thức thực hiện	Lưu ý	Biểu mẫu sử dụng
4. Tech Lead sanity-check	Tech Lead	Kiểm nhanh tính khả thi kỹ thuật của spec.	Chưa phải Gate 2 chính thức, chỉ sanity-check.	—
5. Cập nhật glossary.md	BA	Bổ sung thuật ngữ kỹ thuật mới phát sinh.	—	PL 3.16

B5. Làm rõ & chốt Spec (Clarify) — ⛔ GATE 1

- **Tài liệu đầu ra:** Q&A Log, spec.md bản final, Biên bản duyệt Spec.

Quy tắc: Chưa qua Gate 1 thì không được sinh plan/code. Sau khi Spec đã qua Gate 1, mọi thay đổi phạm vi/thiết kế/yêu cầu nghiệp vụ phải được đệ trình qua Biểu mẫu Yêu cầu Thay đổi (Phụ lục 2) và được PM, PO duyệt trước khi tiến hành.

Lưu đồ thực hiện (bổ sung V5.9)



- **Bảng chi tiết theo từng bước:**

Bước	Người thực hiện	Cách thức thực hiện	Lưu ý	Biểu mẫu sử dụng
1. Tổng hợp câu hỏi mở	BA	Gom toàn bộ mục [CẦN LÀM RÕ] trong spec.md, gửi PO/khách hàng.	—	—
2. AI đọc chéo phát hiện mâu thuẫn	AI	Dùng Spec Kit /speckit.clarify rà toàn bộ spec.md tìm mâu thuẫn/mơ hồ.	—	—
3. Cập nhật Q&A Log, chốt spec	BA	Ghi nhận câu trả lời vào Q&A Log, chỉnh spec.md thành bản final.	—	**Q&A Log — PL 4.5**

4. Họp duyệt Spec	PM	Tổ chức họp với PO/Sponsor, đối chiếu dor-dod.md (mục DoR).	—	dor-dod.md — PL 3.17
5. Ký duyệt — Gate 1	PO/PM	Ký Biên bản duyệt Spec chính thức.	Chưa qua Gate 1 thì không được sinh plan/code.	Chưa có mẫu chuẩn
6. Khóa spec.md	PM	Freeze spec.md bằng tag/branch protection trên Git.	Thay đổi sau đó phải qua CR Form.	CR Form — PL 2

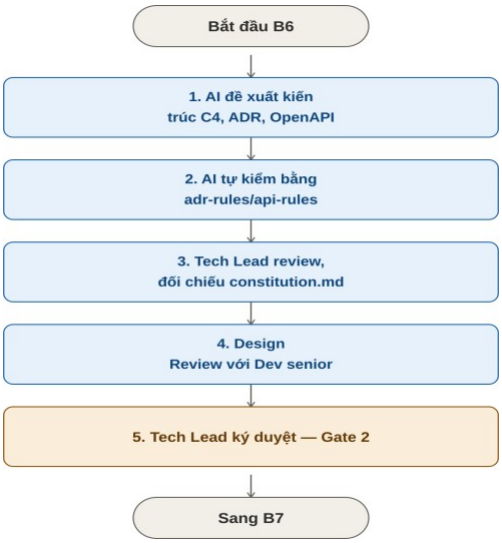
GIAI ĐOẠN 2 — THIẾT KẾ

B6. Technical Plan & Kiến trúc — ⛔ GATE 2

- **Tài liệu đầu ra:** plan.md, ADR, C4 Model, ERD, API Specification (OpenAPI 3.x).

Gate 2: Tech Lead phải duyệt để tránh "architecture by autocomplete".

Lưu đồ thực hiện (bổ sung V5.9)



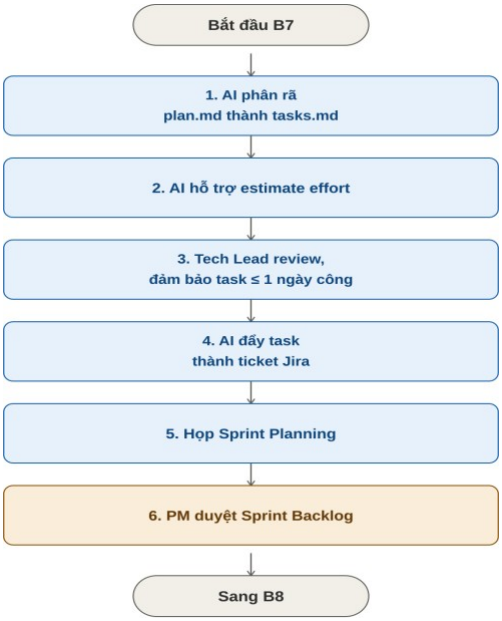
- **Bảng chi tiết theo từng bước:**

Bước	Người thực hiện	Cách thức thực hiện	Lưu ý	Biểu mẫu sử dụng
1. AI đề xuất kiến trúc	Tech Lead	Dùng prompt B6, đưa spec.md cho AI (Claude Code) đề xuất C4, ADR, OpenAPI.	—	adr-template.md — PL 3.3
2. AI tự kiểm	AI	Tự kiểm ADR bằng adr-rules.md, OpenAPI bằng api-rules.md.	—	PL 3.11, 3.12
3. Tech Lead review	Tech Lead	Chỉnh sửa, bổ sung ADR, đối chiếu constitution.md.	—	constitution.md — PL 3.1
4. Design Review	Tech Lead + Dev senior	Phản biện kiến trúc trước khi trình duyệt chính thức.	Khuyến khích, không bắt buộc.	—
5. Ký duyệt — Gate 2	Tech Lead (hoặc Architect/CTO)	Ký duyệt, commit plan.md/ADR/C4/OpenAPI vào repo.	Tránh "architecture by autocomplete".	Chưa có mẫu plan.md/C4

B7. Phân rã Task

- **Tài liệu đầu ra:** tasks.md, Ticket trên Jira, Sprint Backlog.

Lưu đồ thực hiện (bổ sung V5.9)



- **Bảng chi tiết theo từng bước:**

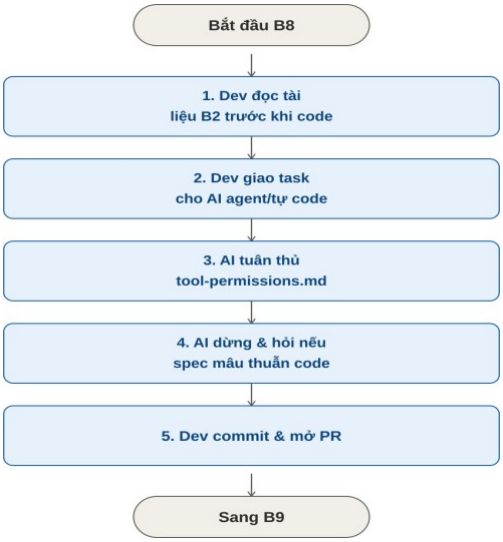
Bước	Người thực hiện	Cách thức thực hiện	Lưu ý	Biểu mẫu sử dụng
1. Phân rã task	Tech Lead + AI	Dùng /speckit.tasks phân rã plan.md thành tasks.md, mỗi task nhỏ có AC riêng.	—	Chưa có mẫu chuẩn
2. AI estimate	AI	Ước lượng effort dựa trên dữ liệu lịch sử (Jira AI/Atlassian Intelligence).	—	—
3. Tech Lead review	Tech Lead	Điều chỉnh, đảm bảo mỗi task ≤ 1 ngày công.	—	—
4. Đẩy ticket	AI	Dùng /speckit.taskstoissues đẩy task thành ticket Jira/Azure DevOps.	—	—
5. Sprint Planning	PM + Tech Lead	Họp chọn task vào Sprint Backlog.	—	—
6. Duyệt Sprint Backlog	PM	Duyệt chính thức backlog cho sprint.	Human Gate nhẹ.	—

GIAI ĐOẠN 3 — LẬP TRÌNH

B8. Coding (AI-assisted / agentic)

Quy tắc: Agent chỉ code trong phạm vi task. Dev chịu trách nhiệm cuối cùng. Commit theo Conventional Commits.

Lưu đồ thực hiện (bổ sung V5.9)



- **Bảng chi tiết theo từng bước:**

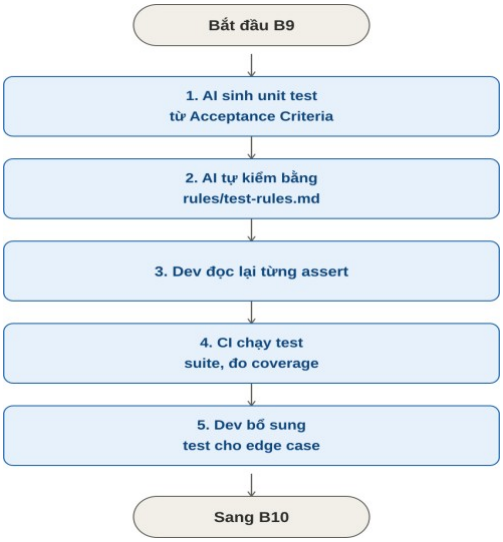
Bước	Người thực hiện	Cách thức thực hiện	Lưu ý	Biểu mẫu sử dụng
1. Đọc tài liệu B2	Dev	Đọc constitution → convention → SKILL.md → spec/plan liên quan trước khi code.	Thứ tự đọc quy định trong SKILL.md.	PL 3.1, 3.2, 3.4
2. Giao task cho AI/code	Dev	Giao AI agent hoặc tự code với inline copilot, đúng phạm vi 1 task.	PR mục tiêu < 400 dòng.	—
3. AI tuân thủ quyền hạn	AI	Tự chạy lint/test cục bộ, không tự merge PR hay push thẳng main.	—	tool-permissions.md — PL 3.5
4. AI dừng khi mâu thuẫn	AI	Dừng lại, hỏi Dev nếu spec và code hiện tại mâu thuẫn.	Không tự suy đoán ý định.	—
5. Commit & mở PR	Dev	Commit theo Conventional Commits, mở PR gắn với ticket tương ứng.	—	—

B9. Unit Test

- **Coverage tối thiểu:** 80% line/branch toàn repo; 100% cho business logic lõi. Cấu trúc test theo AAA (Arrange–Act–Assert).

Lưu ý: AI sinh test từ AC (Gherkin), không sinh test từ code hiện tại — tránh việc AI viết test hợp thức hóa code sai.

Lưu đồ thực hiện (bổ sung V5.9)



- **Bảng chi tiết theo từng bước:**

Bước	Người thực hiện	Cách thức thực hiện	Lưu ý	Biểu mẫu sử dụng
1. AI sinh unit test	AI	Sinh test từ Acceptance Criteria (Gherkin), không sinh từ code.	—	—
2. AI tự kiểm	AI	Tự kiểm bằng rules/test-rules.md trước khi đưa vào PR.	—	PL 3.13
3. Dev đọc assert	Dev	Đọc lại từng assert, xác nhận đúng ý nghĩa nghiệp vụ.	Không chỉ kiểm tra "chạy được".	—
4. CI chạy test	CI (tự động)	Chạy toàn bộ test suite, đo coverage.	Fail pipeline nếu dưới ngưỡng 80%/100%.	—
5. Bổ sung edge case	Dev	Thêm test cho edge case mà AI bỏ sót.	—	—

B10. Code Review 2 tầng — ⛔ GATE 3

- **Tầng 1 (AI review):** Quét bug, convention, code smell, bảo mật. CI chạy SAST, secret scan.
- **Tầng 2 (Human review):** Tập trung nghiệp vụ, kiến trúc, bảo mật. Bắt buộc để được merge; reviewer khác tác giả.

Lưu đồ thực hiện (bổ sung V5.9)



- **Bảng chi tiết theo từng bước:**

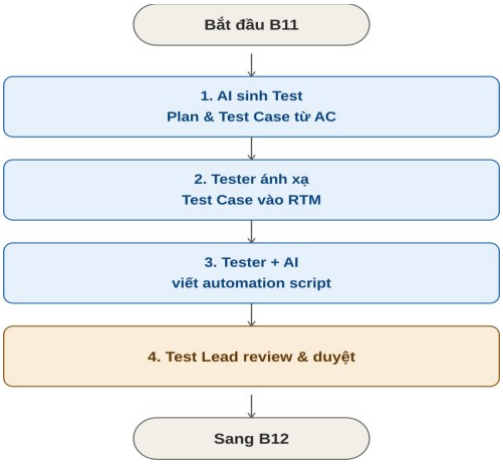
Bước	Người thực hiện	Cách thức thực hiện	Lưu ý	Biểu mẫu sử dụng
1. Kích hoạt AI review	CI (tự động)	Kích hoạt AI review tầng 1 dựa trên code-review-rules.md, song song SAST/secret scan.	—	PL 3.14
2. AI comment finding	AI	Comment trực tiếp trên PR các finding phát hiện được.	—	—
3. Dev sửa finding	Dev	Sửa toàn bộ finding mức High/Critical trước khi mời review.	—	—
4. Mời Human reviewer	Dev	Mời tối thiểu 1 reviewer khác tác giả (2 nếu module lõi/bảo mật).	—	—
5. Reviewer dùng checklist	Reviewer	Review nghiệp vụ, kiến trúc, khả năng bảo trì, tác động chéo.	—	Chưa có checklist riêng
6. Approve PR	Reviewer	Approve khi đạt yêu cầu; branch protection chặn merge nếu thiếu review/CI chưa xanh.	—	—
7. Merge — Gate 3	Tech Lead/Reviewer	Merge PR chính thức.	—	—

GIAI ĐOẠN 4 — KIỂM THỬ

B11. Test Plan & Test Case

- **Tài liệu đầu ra:** Test Plan, Test Case (RTM map với AC), Automation test script.
- **AI khuyến nghị:** Claude sinh test case từ AC; Playwright codegen.

Lưu đồ thực hiện (bổ sung V5.9)



- **Bảng chi tiết theo từng bước:**

Bước	Người thực hiện	Cách thức thực hiện	Lưu ý	Biểu mẫu sử dụng
1. Sinh Test Plan/Case	Test Lead + AI	Sinh từ Acceptance Criteria/ (Tài liệu nghiệp vụ / yêu cầu, Tài liệu thiết kế, Tài liệu dự án,..) bằng prompt tương ứng trong prompts.md.	—	Biểu mẫu do đối tác yêu cầu/Test Plan theo chuẩn ISTQB
2. Ánh xạ RTM	Tester	Ánh xạ Test Case vào RTM (Requirement Traceability Matrix), đảm bảo phủ 100% Acceptance Criteria; gắn nhãn nguồn gốc (AI-generated/Manual) cho từng Test Case.	—	—
3. Viết automation	Tester + AI	Viết automation script (Playwright codegen) cho các luồng chính.	Script AI sinh phải qua rules/code-review-rules.md trước khi merge.	—
4. Duyệt Test Plan/ Test Case	Test Lead	Review & duyệt chính thức.	Human Gate.	—

B12. SIT / Regression / UAT và Kiểm thử Phi chức năng — ⛔ GATE 4 (3 SIGN-OFF THÀNH PHẦN)

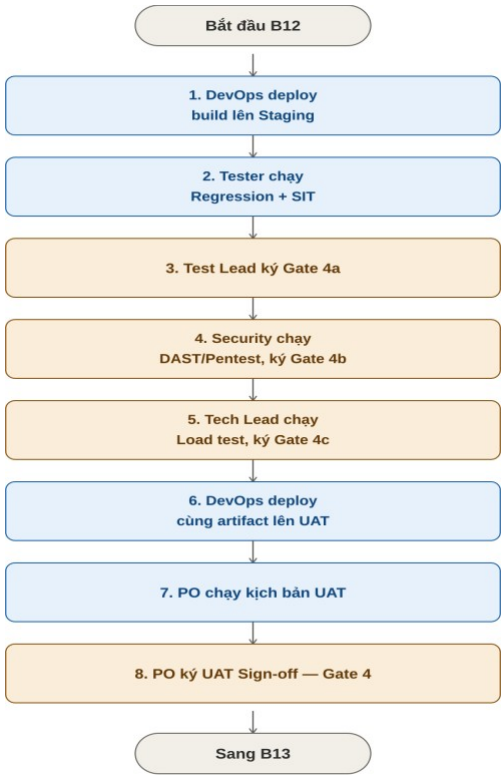
Cập nhật V5.1: Gate 4 trước đây gộp chung dưới một chữ ký PO — nay tách rõ 3 sign-off thành phần theo đúng chuyên môn chịu trách nhiệm, PO chỉ ký sign-off cuối cùng sau khi cả 3 thành phần đã "xanh".

- **Gate 4a — SIT/Regression (người ký: Test Lead):**
  - Deploy build lên môi trường STAGING (bản sao cấu hình gần Production nhất; xem luật thăng cấp môi trường ở B13).
  - Regression suite tự động phải xanh 100%.
  - RTM (Requirements Traceability Matrix) phủ 100% Acceptance Criteria.
- **Gate 4b — An toàn thông tin/ATTT (người ký: Security Lead hoặc đơn vị pentest độc lập):**
  - DAST (Dynamic Application Security Testing) trên môi trường Staging.
  - Penetration Testing giả lập — với hệ thống chạm dữ liệu cá nhân/thanh toán, bắt buộc thuê đơn vị pentest độc lập bên ngoài, tần suất tối thiểu 1 lần/release lớn.
  - Kiểm tra cấu hình tường lửa cơ sở dữ liệu (DBF) và EDR/EPP.
  - Đánh giá phân quyền, cơ chế PAM và MFA cho tài khoản quản trị.
  - Không còn lỗ hổng mức Critical/High chưa vá.
- **Gate 4c — Hiệu năng (người ký: Tech Lead):**

- Load & Stress test bằng JMeter/k6 trên môi trường cấu hình tương đương Production.
- Đánh giá Scalability (auto-scaling) của Microservices.
- Giám sát tài nguyên CPU/RAM/Băng thông; xác nhận đạt SLA hiệu năng đã cam kết trong Spec.

- **Gate 4 — UAT Sign-off (người ký: PO/khách hàng, sau khi 4a+4b+4c đã đạt):**
  - Deploy build (cùng artifact đã qua Staging — xem B13) lên môi trường UAT.
  - Regression suite phải xanh 100%; số lượng bug Severity 1–2 phải bằng 0 mới trình sign-off cho PO.
  - Biên bản UAT Sign-off theo mẫu tại Phụ lục 6.

Lưu đồ thực hiện (bổ sung V5.9)



- **Bảng chi tiết theo từng bước:**

Bước	Người thực hiện	Cách thức thực hiện	Lưu ý	Biểu mẫu sử dụng
1. Deploy Staging	DevOps	Deploy build qua CI/CD, dùng đúng artifact đã build ở B10 (build-once).	—	—
2. Chạy Regression + SIT	Tester	Chạy regression tự động + SIT thủ công cho luồng phức tạp.	Bug phát hiện dùng mẫu Bug Report.	**Bug Report — PL 5**
3. Ký Gate 4a	Test Lead	Ký khi Regression xanh 100% và RTM phủ đủ AC.	Biên bản bàn giao/Nội dung bàn giao	—
4. Chạy ATTT, ký Gate 4b	Security Lead/pentest	DAST + Pentest + kiểm PAM/MFA; ký khi hết lỗ hổng Critical/High.	—	—
5. Load test, ký Gate 4c	Tech Lead + DevOps	Chạy JMeter/k6; ký khi đạt SLA hiệu năng cam kết.	—	—
6. Deploy UAT	DevOps	Deploy cùng artifact (không rebuild) sau khi 4a+4b+4c đã đạt.	—	—
7. Chạy kịch bản UAT	PO/khách hàng	Chạy cùng BA/Tester hỗ trợ giải thích nghiệp vụ.	—	—

8. Ký UAT Sign-off — Gate 4	PO	Ký Biên bản UAT Sign-off chính thức.	—	**UAT Sign-off — PL 6**

GIAI ĐOẠN 5 — PHÁT HÀNH & VẬN HÀNH

B13. Release & Quá trình đưa lên môi trường — ⛔ GATE 5: GO/NO-GO Luật thăng cấp môi trường (Promotion Rules) — bổ sung V5.1

- DEV → CI/TEST → STAGING → UAT → PRODUCTION — mỗi bước chỉ được đi tiếp khi gate tương ứng đã ký.
- **Build một lần, thăng cấp nhiều lần:** cùng một build artifact đi từ Staging → UAT → Production, tuyệt đối không rebuild lại ở mỗi môi trường — tránh lệch giữa cái đã test và cái được deploy.
- **Chỉ deploy qua CI/CD pipeline:** cấm deploy tay/copy file thủ công lên bất kỳ môi trường nào từ Staging trở lên.
- **Infrastructure-as-Code:** mọi thay đổi cấu hình hạ tầng (Terraform/Ansible) phải qua Pull Request và review như code.

Chi tiết từng môi trường

- **Môi trường Staging (SIT):** Bản sao của Production. Chạy Integration, Security và Performance test (Gate 4a/4b/4c). Bắt buộc dùng dữ liệu test giả lập (synthetic data) do AI sinh ra hoặc dữ liệu production đã được che (masking/anonymize) — không dùng dữ liệu thật chưa xử lý.
- **Môi trường UAT:** Dành cho khách hàng/PO trải nghiệm. Chỉ triển khai lên UAT khi Regression test tự động hoàn tất 100% và Gate 4a/4b/4c đã ký.
- **Môi trường Production & Go-live:** Áp dụng chiến lược blue-green hoặc canary. Kiểm soát truy cập nghiêm ngặt qua hệ thống PAM. Bắt buộc đính kèm Rollback Plan chi tiết trong bộ tài liệu Release.

Gate 5 — Họp Go/No-Go (bổ sung V5.1)

Trước go-live bắt buộc tổ chức họp Go/No-Go với sự tham dự của PM, Tech Lead, Test Lead, Security Lead, PO. Checklist tối thiểu tại Phụ lục 6. Chỉ go-live khi tất cả mục checklist là "Đạt"; nếu có mục "Không đạt", quyết định No-Go và dời lịch.

Hypercare (bổ sung V5.1)

- Ngay sau go-live, áp dụng giai đoạn Hypercare 1–2 tuần: đội Dev/DevOps trực theo dõi tăng cường, giám sát dashboard liên tục, SLA phản hồi sự cố rút ngắn (VD: Blocker phản hồi trong 30 phút thay vì 4 giờ).
- Tiêu chí kết thúc Hypercare: hệ thống ổn định liên tục ≥ 5 ngày làm việc không có sự cố Severity 1–2, sau đó bàn giao chính thức cho đội Vận hành (B14) theo Runbook.

Lưu đồ thực hiện (bổ sung V5.9)



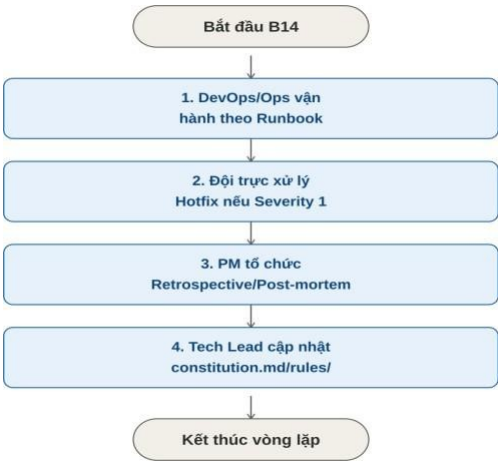
- **Bảng chi tiết theo từng bước:**

Bước	Người thực hiện	Cách thức thực hiện	Lưu ý	Biểu mẫu sử dụng
1. Họp Go/No-Go	PM	Chủ trì họp, rà soát checklist cùng Tech Lead, Test Lead, Security Lead, PO.	—	**Go/No-Go Checklist — PL 6**
2. Xác nhận Rollback & IaC	DevOps	Xác nhận Rollback Plan đã diễn tập, IaC đã review, dashboard sẵn sàng.	—	Chưa có mẫu Rollback Plan
3. Quyết định GO/NO-GO — Gate 5	PM	Ra quyết định chính thức; nếu NO-GO nêu lý do và dời lịch.	—	—
4. Deploy Production	DevOps	Deploy đúng artifact đã qua UAT theo blue-green/canary.	Chỉ khi GO.	—
5. Trực Hypercare	Dev + DevOps	Trực 1-2 tuần, giám sát tăng cường, SLA rút ngắn.	—	—
6. Thông báo go-live	PM	Thông báo cho stakeholder theo Communication Plan.	—	Communication Plan — PL 1

B14. Vận hành & cải tiến

- **Tài liệu:** Runbook, Post-mortem.
- **Cải tiến:** Cập nhật bài học vào constitution.md để quy trình tự tiến hóa.

Lưu đồ thực hiện (bổ sung V5.9)



- **Bảng chi tiết theo từng bước:**

Bước	Người thực hiện	Cách thức thực hiện	Lưu ý	Biểu mẫu sử dụng
1. Vận hành theo Runbook	DevOps/Ops	AI hỗ trợ giám sát log/alert, đề xuất xử lý (SRE agent).	—	Chưa có mẫu Runbook
2. Xử lý Hotfix	Đội trực	Theo quy trình Hotfix Production (mục 3) nếu Severity 1 phát sinh.	—	—
3. Retrospective/ Post-mortem	PM	Tổ chức cuối sprint hoặc sau sự cố lớn, có người chủ trì.	—	Chưa có mẫu Post-mortem
4. Cập nhật constitution.md	Tech Lead	Đưa bài học vào constitution.md/rules/ — khép vòng lặp cải tiến.	—	constitution.md — PL 3.1

3. CÁCH THỨC KIỂM TRA VÀ KIỂM SOÁT BUG PHÁT SINH (DEFECT MANAGEMENT)

- **Phân loại và Phân tích:** Mọi bug report phải theo template chuẩn tại Phụ lục 5 (steps to reproduce, expected vs actual, evidence). Tận dụng AI để gom cụm các bug trùng lặp và phân tích log tìm root cause.

Bảng định nghĩa Severity & SLA

Mức độ (Severity)	Định nghĩa	SLA sửa lỗi (từ lúc xác nhận)
S1 – Blocker	Hệ thống down, mất dữ liệu, chặn toàn bộ luồng nghiệp vụ chính, lỗ hổng bảo mật khai thác được ngay.	4 giờ
S2 – Critical	Một chức năng chính không dùng được, không có workaround, ảnh hưởng nhiều người dùng.	1 ngày làm việc
S3 – Major	Chức năng phụ lỗi hoặc chức năng chính lỗi nhưng có workaround.	3–5 ngày làm việc (theo sprint)
S4 – Minor	Lỗi giao diện, chính tả, không ảnh hưởng nghiệp vụ.	Backlog, xử lý theo ưu tiên sprint

Bảng định nghĩa Priority

Mức độ ưu tiên (Priority)	Ý nghĩa
P1 – Khẩn cấp	Xử lý ngay lập tức, có thể phá quy trình sprint bình thường (áp dụng quy trình Hotfix).
P2 – Cao	Ưu tiên xử lý trong sprint hiện tại.
P3 – Trung bình	Đưa vào backlog, lên kế hoạch sprint kế tiếp.
P4 – Thấp	Xử lý khi có nguồn lực rảnh, không cam kết thời gian.

Vòng đời bug (Bug Lifecycle) — bổ sung V5.1

- New → Triage → Assigned → In Progress → Fixed → Retest → Closed (hoặc → Reopen nếu retest fail).
- **Triage Board:** họp phân loại bug định kỳ hằng ngày (dự án đang test tích cực) do Test Lead chủ trì, có PM/Tech Lead tham gia — quyết định Severity/Priority chính thức, gán người xử lý.
- **Quyền chuyển trạng thái:** chỉ người báo lỗi/Test được đóng bug ở bước Retest; Dev không được tự đóng bug mình sửa.

Quy trình Hotfix Production (bổ sung V5.1)

Áp dụng khi phát sinh sự cố Severity 1 trên Production sau go-live — vẫn giữ gate tối thiểu, không bỏ qua hoàn toàn kiểm soát:

- 1. Xác nhận sự cố & tạo nhánh hotfix từ commit đang chạy Production.
- 2. Fix tối thiểu đúng phạm vi sự cố — không tranh thủ sửa thêm việc khác.
- 3. Unit test cho phần fix (bắt buộc, kể cả hotfix khẩn cấp) + chạy nhanh bộ regression smoke-test (tập con quan trọng nhất, không chờ full suite).
- 4. Human review bắt buộc tối thiểu 1 người (có thể rút gọn 2 tầng review nhưng không được bỏ hẳn review người).
- 5. Deploy thẳng lên Production theo quy trình CI/CD (không deploy tay), có giám sát trực tiếp sau deploy.
- 6. Bắt buộc thực hiện RCA (Root Cause Analysis)/Post-mortem trong vòng 48 giờ sau khi ổn định, cập nhật bài học vào constitution.md/rules nếu liên quan đến quy trình AI.
- **Tiêu chí kiểm soát chung:** Tuân thủ nguyên tắc Zero-Bug đối với lỗi nghiêm trọng; tuyệt đối không đưa lên UAT hoặc Go-live nếu còn bug Severity 1–2.

4. MA TRẬN RACI ĐẦY ĐỦ (14 BƯỚC × 7 VAI TRÒ) — bổ sung V5.1

R = Thực hiện · A = Chịu trách nhiệm cuối cùng · C = Tham vấn · I = Được thông báo · 🤖 = AI hỗ trợ/thực thi dưới giám sát. Cập nhật: bổ sung 3 vai trò PO/Sponsor, Security, DevOps/Ops vốn bị thiếu ở bản V5.

Bước	PM	BA	Dev/Tech Lead	Test	PO/ Sponsor	Security	DevOps/ Ops	AI
B1. Charter & Kick-off	A/R	C	C	I	C	I	I	draft, tóm tắt
B2. Constitution & skill.md	A	C	R	C	I	C	I	sinh khung
B3. Thu thập yêu cầu	I	A/R	C	I	C	I	I	ghi họp, trích yêu cầu
B4. Viết Spec	I	A/R	C	C	C	I	I	draft story/AC
B5. Chốt Spec (Gate 1)	A	R	C	C	A	I	I	soát mâu thuẫn
B6. Plan & Kiến trúc (Gate 2)	I	C	A/R	C	I	C	C	draft plan, ADR
B7. Phân rã Task	A	C	R	C	I	I	I	sinh task, estimate
B8. Coding	I	I	A/R	I	I	I	I	thực thi chính
B9. Unit Test	I	I	A/R	C	I	I	I	sinh test từ AC
B10. Code Review (Gate 3)	I	I	A/R	I	I	C	I	review tầng 1
B11. Test Plan/Case	I	C	C	A/R	I	I	I	sinh test case
B12. SIT/ATTT/Hiệu năng/UAT (Gate 4)	A	C	C (fix bug)	R (4a)	A (UAT)	A/R (4b)	C (4c)	phân loại bug
B13. Release/Go-live (Gate 5)	A	I	R	C	A	C	R	changelog, checklist
B14. Vận hành & cải tiến	A	I	R	C	I	C	R	giám sát, đề xuất fix

Nguyên tắc xuyên suốt: AI không bao giờ giữ vai trò A (Accountable). Trách nhiệm cuối cùng luôn thuộc về con người. Ở B12, Gate 4 tách 3 sign-off: Test Lead sở hữu 4a, Security Lead sở hữu 4b (A/R), Tech Lead tham vấn 4c, PO là Accountable cho sign-off UAT cuối cùng.

5. TÓM TẮT CHUẨN ÁP DỤNG & CÔNG CỤ AI

- **Kiến trúc & Code:** C4 Model, ADR, OpenAPI 3.x, Conventional Commits.
- **Bảo mật:** OWASP ASVS, OWASP Top 10, OWASP LLM Top 10 (rủi ro riêng khi dùng AI).
- **Kiểm thử & QA:** ISO/IEC/IEEE 29119, ISTQB.
- **Công cụ nổi bật:** GitHub Spec Kit, Claude Code (Agentic), CodeRabbit (Review), Playwright (Automation).

Quản trị công cụ AI (AI Tool Governance) — bổ sung V5.1

- Mọi công cụ AI mới trước khi dùng cho dự án có NDA/dữ liệu khách hàng phải qua đánh giá bảo mật dữ liệu: dữ liệu prompt có bị dùng để train mô hình không, có tùy chọn opt-out/zero-data-retention không, dữ liệu lưu trữ ở khu vực địa lý nào.
- Công ty duy trì danh sách "AI tool được duyệt" (approved list); dự án chỉ được dùng tool ngoài danh sách này khi có phê duyệt riêng của Tech Lead + phòng An ninh thông tin.

Bản quyền / IP của code do AI sinh ra — bổ sung V5.1

- Bật chế độ lọc trùng lặp mã nguồn công khai (public code duplication filter) trên các công cụ hỗ trợ (VD: GitHub Copilot) để giảm rủi ro sao chép license GPL/copyleft không tương thích.
- Quét license của dependency bằng công cụ chuyên dụng (FOSSA/Snyk) trước khi release, đặc biệt với dự án outsource có điều khoản sở hữu trí tuệ trong hợp đồng.
- Điều khoản hợp đồng với khách hàng cần nêu rõ trách nhiệm khi có tranh chấp bản quyền phát sinh từ code do AI hỗ trợ sinh ra.

6. LUỒNG RÚT GỌN CHO TASK NHỎ

Đối với các task < 0,5 ngày công không chạm phân quyền/thanh toán và không thay đổi data model: Bỏ qua B4–B7 đầy đủ, mô tả thẳng vào ticket. Vẫn bắt buộc unit test, AI review tầng 1, human review tầng 2.

(Sửa lỗi tham chiếu V5.1: mục 1 trước đây trỏ nhầm sang mục 7 — luồng rút gọn nằm ở mục 6 này.)

7. CHÍNH SÁCH SKILL.MD

- **Tầng 1 (Công ty):** Chuẩn bảo mật, quy trình cốt lõi — áp dụng bắt buộc mọi dự án. Là tài sản tri thức tích lũy của công ty, được cập nhật từ bài học B14.
- **Tầng 2 (Dự án/Đối tác):** Convention, kiến trúc riêng — định hình code deliverable. Khi làm trên codebase có sẵn của đối tác, tầng này quyết định hình hài code (giống code của họ, không phải giống code chuẩn nội bộ).
- **Quy tắc ưu tiên khi xung đột:** Bảo mật/Pháp lý công ty luôn thắng; Style/Convention theo đối tác.

Kiểm duyệt skill.md của đối tác — bổ sung V5.1

File chỉ dẫn AI agent (skill.md, system prompt do đối tác cung cấp) là một vector prompt injection tiềm ẩn — có thể chứa chỉ dẫn ẩn khiến agent gửi code/secret ra ngoài. Tech Lead bắt buộc đọc toàn bộ nội dung skill.md/tài liệu chỉ dẫn của đối tác trước khi nạp vào ngữ cảnh AI agent. Không đưa bí mật công ty (API key, tên khách hàng khác, know-how định giá...) vào skill.md dùng chung với môi trường đối tác.

8. KPI THEO DÕI HIỆU QUẢ

- Lead time từ Spec đến Code merge (DORA metrics).
- Tỷ lệ PR bị AI chặn lỗi trước khi tới người.
- Escaped defects (bug lọt ra sau UAT).
- Mutation score đo chất lượng test.

PHỤ LỤC: CÁC BIỂU MẪU CHUẨN HÓA

PHỤ LỤC 1: BIỂU MẪU B1 — KHỞI TẠO DỰ ÁN (PROJECT CHARTER & KICK-OFF)

Phần 1: Project Charter

- **1.1. Thông tin chung:** Tên dự án / Mã dự án / PM / Sponsor / Ngày bắt đầu / Ngày kết thúc dự kiến.
- **1.2. Mục tiêu dự án (SMART)**
- **1.3. Phạm vi dự án:** In-scope / Out-of-scope.
- **1.4. Ngân sách dự kiến**

1.5. Các mốc thời gian quan trọng (Milestones)

STT	Tên cột mốc (Milestone)	Ngày dự kiến	Đầu ra (Deliverables)
1	Chốt Spec (Gate 1)	[Ngày]	Tài liệu Spec được ký duyệt
2	Chốt Kiến trúc (Gate 2)	[Ngày]	Technical Plan & C4 Model
3	Sẵn sàng UAT (Gate 4a/4b/4c đạt)	[Ngày]	Hệ thống deploy lên Staging, ATTT & Hiệu năng đạt
4	UAT Sign-off (Gate 4)	[Ngày]	Biên bản UAT ký bởi PO
5	Go-live (Gate 5: Go/No-Go)	[Ngày]	Triển khai Production + Hypercare

(Sửa lỗi V5.1: mốc "Go-live" trước đây gắn nhầm với "Gate 4" — nay Gate 4 là UAT sign-off, Go-live là Gate 5 riêng theo Go/No-Go checklist ở Phụ lục 6.)

1.6. Rủi ro sơ bộ

STT	Mô tả rủi ro	Ảnh hưởng	Khả năng	Giảm thiểu
1	Thay đổi yêu cầu nghiệp vụ liên tục	Cao	Cao	Áp dụng quy trình chốt Spec Gate 1 chặt chẽ
2	[Rủi ro 2...]			

- **1.7. Giả định và Ràng buộc (Assumptions & Constraints)**
- **1.8. Tiêu chí thành công và Nghiệm thu (Success Criteria)**

Phần 2: Stakeholder Register

STT	Họ và Tên	Vai trò	Ảnh hưởng	Quan tâm	Kỳ vọng chính
1	[Tên]	Project Sponsor	Cao	Cao	Dự án đúng tiến độ, tối ưu chi phí
2	[Tên]	Product Owner	Cao	Cao	Đáp ứng đúng luồng nghiệp vụ
3	[Tên]	Tech Lead	Cao	TB	Kiến trúc chuẩn, dễ bảo trì
4	[Tên]	Security Lead	Cao	TB	Không có lỗ hổng Critical/High khi go-live
5	[Tên]	End-User đại diện	TB	Cao	Hệ thống dễ dùng, không lỗi

Phần 3: Communication Plan

STT	Loại thông tin	Đối tượng nhận	Tần suất	Kênh & Lưu trữ	Người chịu trách nhiệm

1	Báo cáo tiến độ	Sponsor, PO, Nhóm dự án	Hàng tuần	Hệ thống QLDA / Confluence	Project Manager
2	Sprint Planning/Review	PO, Nhóm dự án	Đầu/ Cuối Sprint	Họp trực tiếp/Teams	Scrum Master/PM

STT	Loại thông tin	Đối tượng nhận	Tần suất	Kênh & Lưu trữ	Người chịu trách nhiệm
3	Cảnh báo rủi ro/Blocker	PO, Tech Lead	Ngay lập tức	Kênh Slack riêng	Bất kỳ thành viên nào
4	Ký duyệt tài liệu (Gate)	PO, Sponsor, Tech Lead	Theo Milestone	Ký bản cứng/điện tử	Project Manager

Giám đốc dự án (PM): _____ Ngày: ____/____/20___

Nhà tài trợ (Sponsor/PO): _____ Ngày: ____/____/20___

PHỤ LỤC 2: BIỂU MẪU YÊU CẦU THAY ĐỔI (CHANGE REQUEST FORM)

Phần 1: Thông tin chung

- Tên dự án / Mã yêu cầu (CR ID) / Người yêu cầu / Ngày yêu cầu.
- Mức độ ưu tiên: ☐ Thấp ☐ Trung bình ☐ Cao ☐ Khẩn cấp (Blocker).

Phần 2: Chi tiết yêu cầu thay đổi

- **2.1. Mô tả sự thay đổi (What)**
- **2.2. Lý do thay đổi (Why)**
- **2.3. Tài liệu liên quan cần cập nhật:** ☐ Charter (B1) ☐ Spec/SRS (B4) ☐ Plan/C4 (B6) ☐ Test Plan (B11).

Phần 3: Đánh giá tác động (PM & Tech Lead)

Hạng mục tác động	Đánh giá chi tiết
1. Phạm vi (Scope)	[Khối lượng công việc phát sinh thêm; ảnh hưởng tính năng khác?]
2. Tiến độ (Schedule)	[Man-day phát sinh; ảnh hưởng ngày Go-live?]
3. Ngân sách (Budget)	[Chi phí phát sinh; cần license/server thêm?]
4. Kiến trúc/Hệ thống	[Phá vỡ kiến trúc hiện tại? Ảnh hưởng hiệu năng/bảo mật?]

- **Phương án đề xuất:** Chấp nhận và lùi tiến độ / Làm Phase 2 / Từ chối...

Phần 4: Quyết định phê duyệt

- ☐ Phê duyệt ☐ Phê duyệt có điều kiện ☐ Từ chối ☐ Tạm hoãn.

Giám đốc dự án (PM): _____ Ngày: ____/____/20___

Tech Lead: _____ Ngày: ____/____/20___

Nhà tài trợ / PO: _____ Ngày: ____/____/20___

PHỤ LỤC 3: BỘ TÀI LIỆU DỰ ÁN B2 ĐẦY ĐỦ (CONSTITUTION, CONVENTION, SKILL.MD VÀ CÁC FILE MỞ RỘNG)

Copy nội dung dưới đây vào các file tương ứng tại thư mục gốc của dự án — đây là "bộ não" điều khiển AI Agent và tiêu chuẩn hóa làm việc cho đội ngũ. Cập nhật V5.4: gộp Phụ lục 3 và Phụ lục 7 (V5.2) thành một phụ lục duy nhất. Cập nhật V5.5: mỗi mục có thêm phần "Cách dựng" (ai dựng, dựng thế nào, dựa trên chuẩn nào) và nội dung mẫu được viết đầy đủ hơn thay vì chỉ liệt kê gạch đầu dòng.

NHÓM 1 — QUY ĐỊNH KỸ THUẬT

3.1. constitution.md (Hiến pháp dự án)

Cách dựng: Tech Lead chạy lệnh /speckit.constitution (GitHub Spec Kit) ngay sau khi khởi tạo repo ở B2, trước khi bất kỳ tính năng nào được viết — vì mọi lệnh sau đó (/speckit.specify, /speckit.plan, /speckit.tasks) đều đối chiếu ngược lại file này. AI thu thập input từ Tech Lead + ngữ cảnh repo, điền vào bản mẫu có placeholder, rồi tự động lan truyền thay đổi xuống các template phụ thuộc (plan-template.md, spec-template.md, tasks-template.md). Chỉ Tech Lead được duyệt thay đổi file này, luôn qua Pull Request.

- **Mỗi nguyên tắc PHẢI có đủ 3 phần:** Rule (câu lệnh MUST/SHOULD đo lường được — không viết chung chung), Rationale (tại sao tồn tại), Application (áp dụng cụ thể ra sao).

```
# Project Constitution: [Tên dự án]

**Version**: 1.0.0
**Ratified**: [ngày ký Gate B2]
**Last Amended**: [ngày ký Gate B2]
```

- **Nguyên tắc 1 — Kiến trúc đơn giản, nhất quán:**
  - Rule: Hệ thống PHẢI theo Microservices First, Stateless Services, API First, Fail-Fast. Tối đa 3 service cho MVP trừ khi có ADR justify thêm.
  - Rationale: Phức tạp sớm làm AI agent dễ "lạc" trong kiến trúc rối, sinh code sai chỗ.
  - Application: Không dùng Repository pattern trừ khi độ phức tạp truy cập dữ liệu thực sự cần; không session state phía server (dùng JWT); vượt 3 service phải có ADR giải trình.
- **Nguyên tắc 2 — Bảo mật mặc định (Security By Default):**
  - Rule: Hệ thống PHẢI mã hóa dữ liệu khi truyền/lưu trữ, validate mọi input, tuân thủ OWASP Top 10, không hardcode secret.
  - Rationale: Bảo mật không thể "gắn thêm sau" — làm từ đầu giảm bề mặt tấn công, tránh retrofit tốn kém.
  - Application: Zero Trust (JWT/Auth Header mọi request); tuyệt đối không log PII (đối chiếu data-classification.md); secret qua Vault/Env, không commit repo; mọi thay đổi liên quan auth bắt buộc Security review.
- **Nguyên tắc 3 — Khả năng quan sát (Observability):**
  - Rule: Mọi service PHẢI log có cấu trúc JSON, gắn correlation_id xuyên suốt chuỗi gọi.
  - Rationale: Không có log có cấu trúc, debug hệ thống agentic (nơi AI tự sinh code) gần như bất khả thi khi có sự cố production.
  - Application: correlation_id sinh ở entry point, truyền qua toàn bộ downstream call; format log JSON thống nhất; không log PII dù ở mức DEBUG.
- **Nguyên tắc 4 — Test-Driven Quality:**
  - Rule: Mọi tính năng PHẢI có unit test sinh từ Acceptance Criteria (không sinh từ code); coverage tối thiểu 80%, 100% cho business logic lõi.
  - Rationale: Test sinh từ AC là "hợp đồng" — ngăn AI viết test hợp thức hóa code sai (xem rules/test-rules.md).
  - Application: CI chặn merge nếu dưới ngưỡng coverage; assert phải kiểm tra hành vi nghiệp vụ, không chỉ "chạy không lỗi".
- **Governance — Quy trình sửa đổi:**
  - Đề xuất qua Pull Request kèm lý do/use case cụ thể → Tech Lead duyệt → cập nhật version theo semantic versioning (MAJOR: loại bỏ/đổi không tương thích ngược; MINOR: thêm nguyên tắc mới; PATCH: làm rõ câu chữ) → đồng bộ xuống plan-template, tasks-template, SKILL.md nếu bị ảnh hưởng.
  - Rà soát định kỳ: hằng quý kiểm tra nguyên tắc còn phù hợp; sau mỗi release lớn xác nhận không có

vi phạm phát sinh.

3.2. CODING_CONVENTION.md

Cách dựng: Tech Lead soạn dựa trên stack đã chọn ở B1, lấy style guide chính thức của ngôn ngữ làm nền (PEP8/Black cho Python, Google Java Style, Airbnb cho JS/TS...) — không viết lại từ đầu, chỉ liệt kê phần khác biệt hoặc siết chặt hơn so với chuẩn gốc.

- **Naming convention:**

Đối tượng	Quy tắc	Ví dụ
Class / Interface	PascalCase, danh từ	UserRepository, IPaymentGateway
Function / Method	camelCase, động từ + danh từ	calculateInvoiceTotal(), validateUserInput()
Biến / Constant	camelCase (biến), UPPER_SNAKE_CASE (const)	retryCount, MAX_RETRY_ATTEMPTS
File / Folder	kebab-case	user-profile.service.ts, order-management/
DB table / column	snake_case, số nhiều cho table	user_accounts, created_at
Nhánh Git	<type>/<ticket-id>-<mô tả ngắn>	feature/PROJ-123-add-payment
Biến môi trường	UPPER_SNAKE_CASE, prefix theo service	PAYMENT_SERVICE_DB_URL

- **Formatting & Linting — công cụ bắt buộc theo ngôn ngữ:**

Ngôn ngữ	Formatter	Linter	Config file
Python	Black	Ruff	pyproject.toml [tool.ruff]
TypeScript / JS	Prettier	ESLint	.eslintrc.json, .prettierrc
Java	google-java-format	Checkstyle	checkstyle.xml
Go	gofmt	golangci-lint	.golangci.yml

- Indentation theo mặc định của formatter (2 hoặc 4 space) — không tùy chỉnh tay.
- CI chặn merge nếu lint fail (tham chiếu B10 — AI review tầng 1).
- **Cấu trúc thư mục chuẩn:**

```
src/
├── controllers/     # nhận request, gọi service, KHÔNG chứa business logic
├── services/        # business logic
├── repositories/    # truy cập dữ liệu
├── models/          # entity/schema
├── dto/             # request/response object
├── middlewares/
├── utils/
└── config/
tests/
├── unit/
└── integration/
```

- **Error handling:**
  - Không bao giờ để empty catch block.
  - Custom exception class theo domain, kế thừa 1 base AppError chung.
  - Error response format thống nhất toàn API (tham chiếu rules/api-rules.md).
- **Documentation:**
  - Mọi public API bắt buộc Docstring/JSDoc; comment tập trung vào "Tại sao" (Why), không lặp lại "Cái gì" (What) mà code đã tự nói.

```
/**
  * Tính tổng giá trị đơn hàng bao gồm thuế và phí ship.
  * @param order - Đơn hàng cần tính
  * @returns Tổng giá trị đã bao gồm thuế/phí
  */
```

`function calculateOrderTotal(order: Order): number { ... }`

3.3. adr-template.md — Khuôn mẫu Architecture Decision Record

Cách dùng: mỗi quyết định kiến trúc quan trọng tạo 1 file riêng trong docs/adr/, đặt tên ADR-0001-tieu-de-ngan.md, đánh số tăng dần. Không sửa lại ADR cũ đã ở trạng thái Accepted — nếu đổi ý thì tạo ADR mới ghi "Supersedes ADR-000X".

ADR-[số]: [Tên quyết định kiến trúc]

- **Status:** [Proposed / Accepted / Deprecated / Superseded by ADR-xxx]
- **Context:** [Bối cảnh và vấn đề cần giải quyết — tại sao quyết định này cần thiết]
- **Decision:** [Quyết định cuối cùng được chọn]

Phương án	Ưu điểm	Nhược điểm	Lý do không chọn
[Phương án A — được chọn]	[...]	[...]	—
[Phương án B]	[...]	[...]	[Lý do]
[Phương án C]	[...]	[...]	[Lý do]

- **Consequences (Positive):** [Tác động tích cực dự kiến]
- **Consequences (Negative/Trade-off):** [Đánh đổi phải chấp nhận]
- **ADR liên quan:** [ADR-xxx nếu có]

NHÓM 2 — QUY ĐỊNH VẬN HÀNH AI

3.4. SKILL.md (Luật điều khiển AI Agent)

Cách dựng: Tech Lead soạn Tầng 1 dựa trên chuẩn chung của công ty (copy từ dự án trước/template công ty — áp dụng mọi dự án), sau đó bổ sung Tầng 2 riêng cho domain/stack của dự án này. Sau khi hoàn thiện, đồng bộ nội dung ra AGENTS.md ở gốc repo để mọi AI agent (Claude Code, Copilot, Cursor...) đọc được, tránh duy trì nhiều file trùng lặp dễ lệch nội dung. Nếu là skill.md do đối tác cung cấp, Tech Lead phải đọc và kiểm duyệt toàn bộ trước khi nạp — chống prompt injection (xem mục 2/B2).

- **1. Identity — AI đang là ai trong dự án này:**
  - Ví dụ: "Bạn là AI agent hỗ trợ coding cho dự án [tên]. Vai trò của bạn là thực thi task được giao trong Sprint Backlog, không tự ý mở rộng phạm vi ngoài task."
- **2. Thứ tự đọc bắt buộc trước khi code (Context Loading Order):**
  - (1) constitution.md → (2) CODING_CONVENTION.md → (3) SKILL.md (chính file này) → (4) glossary.md → (5) spec.md/plan.md của task liên quan.
- **3. Phạm vi được phép / không được phép (tóm tắt — chi tiết đầy đủ ở tool-permissions.md):**
  - Được: đọc code, sinh code trong phạm vi task, tự chạy test/lint, mở PR.
  - Không được: merge PR, chạy migration DB, push thẳng main, xóa test, truy cập dữ liệu production thật.
- **4. Quy tắc xử lý khi không chắc chắn:**
  - Nếu spec và code hiện tại mâu thuẫn → DỪNG LẠI, hỏi Dev, không tự suy đoán ý định.
  - Nếu gặp thuật ngữ nghiệp vụ không có trong glossary.md → hỏi BA, không tự dịch/suy diễn.
- **5. Workflow coding chi tiết:**
  - Bước 1: Đọc task + Acceptance Criteria liên quan trong tasks.md.
  - Bước 2: Code đúng phạm vi 1 task, PR mục tiêu < 400 dòng.
  - Bước 3: Sinh Unit Test từ Acceptance Criteria (Gherkin), không sinh từ code.
  - Bước 4: Tự chạy lint + test cục bộ, tự kiểm bằng rules/ tương ứng giai đoạn.
  - Bước 5: Commit theo Conventional Commits, mở PR gắn ticket.
- **6. Tầng 1 – Công ty (bắt buộc, áp dụng mọi dự án):**
  - Không gửi dữ liệu khách hàng thật vào prompt (xem data-classification.md).
  - Luôn tự kiểm Unit Test/Linter/Secret Scan trước khi tạo PR.
  - Không tự ý sửa/xóa file cấu hình agent (SKILL.md/AGENTS.md) đang chạy — mọi thay đổi qua PR.
- **7. Tầng 2 – Dự án (riêng dự án này):**
  - Domain & thuật ngữ: theo glossary.md — VD "Order" luôn nghĩa là đơn hàng B2B, không phải giỏ

hàng.

- Constraint riêng: [VD: không đổi cấu trúc bảng users khi chưa có ADR duyệt].
- Nếu dự án dùng codebase có sẵn của đối tác: convention Tầng 2 theo code hiện có của đối tác, không theo CODING_CONVENTION.md chuẩn công ty (xem mục 7 — chính sách skill.md).

3.5. tool-permissions.md — Quyền hạn hành động của AI Agent

Cách dựng: PM + Tech Lead thống nhất dựa trên mức độ rủi ro của từng hành động (nguyên tắc least-privilege); rà soát lại mỗi khi dự án bổ sung loại AI agent mới (VD: thêm SRE agent tự động ở B14).

Hành động	Được tự động thực hiện?	Điều kiện / Ghi chú
Chạy unit test / lint / build cục bộ	Có	Không giới hạn
Tạo nhánh (branch) mới	Có	Theo naming convention trong CODING_CONVENTION.md
Mở Pull Request	Có	Phải gắn task/ticket, mô tả rõ phạm vi
Merge Pull Request	❌ Không	Bắt buộc người duyệt (Gate 3)
Chạy migration cơ sở dữ liệu	❌ Không	Chỉ Dev/DevOps chạy tay sau khi review riêng
Push trực tiếp lên nhánh main/production	❌ Không	Luôn qua PR + CI/CD
Xóa file test đã có	❌ Không	Phải hỏi người nếu thấy test không còn phù hợp
Cài thêm dependency mới	Có điều kiện	Phải nêu lý do trong PR; quét license trước khi merge
Truy cập dữ liệu Production thật	❌ Không	Chỉ dùng dữ liệu Staging/synthetic
Gặp mâu thuẫn giữa spec và code hiện tại	⏸ Dừng & hỏi người	Không tự suy đoán ý định, phải escalate

3.6. data-classification.md — Phân loại dữ liệu & quy tắc dùng với AI

Cách dựng: Security Lead chủ trì, đối chiếu chính sách bảo vệ dữ liệu của công ty và quy định pháp luật liên quan (VD: quy định về bảo vệ dữ liệu cá nhân nếu dự án xử lý dữ liệu người dùng).

Mức phân loại	Ví dụ	Được đưa vào prompt AI?	Yêu cầu xử lý trước khi dùng
Public	Tài liệu marketing, spec tính năng đã công bố	Có, không hạn chế	Không cần xử lý
Internal	Sơ đồ kiến trúc nội bộ, coding convention	Có, chỉ với tool trong ai-tool-scope.md	Không gửi ra ngoài công ty
Confidential	Dữ liệu khách hàng B2B, hợp đồng, chiến lược giá	Chỉ với tool có Zero Data Retention đã duyệt	Ẩn danh hóa các trường định danh trước khi đưa vào prompt nếu có thể
Restricted (PII/PCI)	CMND/CCCD, số thẻ, số điện thoại, bệnh án	Không — cấm tuyệt đối đưa vào prompt AI dưới mọi hình thức	Dùng dữ liệu synthetic/giả lập thay thế (xem quy tắc sinh dữ liệu test ở B13)

3.7. ai-tool-scope.md — Danh mục AI tool được duyệt cho dự án

Cách dựng: Tech Lead + Security thu hẹp từ danh sách AI tool được duyệt chung của công ty (mục 5) xuống danh sách thực sự dùng cho dự án này, xét thêm yêu cầu bảo mật riêng nếu khách hàng có NDA.

Công cụ	Mục đích dùng trong dự án	Dữ liệu tối đa cho phép	Zero Data Retention?	Người phê duyệt
Claude Code	Coding agentic, sinh test, review	Confidential (đã ẩn danh)	Có	Tech Lead
GitHub Copilot	Inline suggestion khi code	Internal	Theo cấu hình tổ chức	Tech Lead
CodeRabbit	AI review tầng 1 trên PR	Internal	Có	Tech Lead + Security
ChatGPT (web)	—	KHÔNG được dùng cho dự án này	Không áp dụng	Không duyệt
[Tool khác...]	[...]	[...]	[...]	[...]

NHÓM 3 — QUY ĐỊNH & THƯ VIỆN PROMPT

3.8. prompts.md (Thư viện Prompt theo giai đoạn)

Cách dựng: Tech Lead/BA khởi tạo bộ prompt ban đầu cho B3/B4/B6 (3 giai đoạn AI sinh nội dung phức tạp nhất), rồi mở rộng dần sang B9/B10/B13 khi thấy AI hay lệch kết quả mong muốn ở giai đoạn nào. Mỗi prompt nên có đủ 4 phần: (1) Vai trò AI cần đóng, (2) Input cụ thể, (3) Định dạng output, (4) Ràng buộc/việc cấm.

- **B3 — Trích xuất yêu cầu → BRD:** "Bạn là một Business Analyst chuyên nghiệp. Dưới đây là [Transcript]. Hãy điền vào [Mẫu BRD]. Nếu thông tin thiếu, ghi [CẦN LÀM RÕ]..."
- **B4 — BRD → Spec.md:** "Bạn là một System Architect. Dựa trên [BRD], hãy viết [Spec.md] theo chuẩn Spec Kit, phân rã User Story theo INVEST và Acceptance Criteria theo Gherkin."
- **B6 — Spec → Technical Plan:** "Bạn là một Tech Lead. Dựa trên [Spec.md], đề xuất kiến trúc C4, ADR, API Specs (OpenAPI 3.x), tuân thủ [constitution.md]."
- **B9 — AC → Unit Test:** "Bạn là một Dev cẩn trọng. Dựa trên [Acceptance Criteria dạng Gherkin] của task này, sinh Unit Test theo cấu trúc AAA, đặt tên theo pattern should_<kỳ vọng>_when_<điều kiện>. TUYỆT ĐỐI không đọc code hiện tại để suy ngược test — chỉ dựa vào AC."
- **B10 — Code Review tầng 1:** "Bạn là một Senior Reviewer. Rà soát diff PR này theo [rules/code-review-rules.md]. Với mỗi finding, ghi rõ mức độ (Critical/High/Medium/Low), vị trí, và đề xuất fix. Không tự sửa code, chỉ comment."
- **B11 — AC → Test Case:** "Bạn là một Test Lead giàu kinh nghiệm. Dựa trên [Acceptance Criteria dạng Gherkin], sinh Test Case đầy đủ theo mẫu chuẩn của dự án, bao gồm cả positive, negative và edge case. Mỗi Test Case phải gắn ID tham chiếu đúng AC nguồn. TUYỆT ĐỐI không tự suy diễn thêm nghiệp vụ ngoài phạm vi AC đã cho."
- **B13 — Release Notes:** "Bạn là Release Manager. Dựa trên danh sách Conventional Commits từ [tag trước] đến [tag hiện tại], tổng hợp Release Notes theo nhóm Features/Fixes/Breaking Changes, ngôn ngữ dễ hiểu cho người dùng cuối."
- **Nguyên tắc viết 1 prompt tốt cho thư viện này:**
  - Luôn gán vai trò cụ thể (role) — giúp AI bám đúng góc nhìn chuyên môn.
  - Input đặt trong ngoặc vuông [Tên biến] để dễ thay thế khi dùng thật.
  - Nêu rõ định dạng output mong muốn (Markdown, JSON, theo mẫu Phụ lục nào).
  - Luôn có ít nhất 1 câu ràng buộc "không được làm gì" — đây là chỗ ngăn AI vượt phạm vi nhiều nhất.

NHÓM 4 — QUY TẮC KIỂM TRA (rules/)

Cách dựng chung cho cả nhóm: chủ sở hữu tương ứng (BA cho brd/bpm, Tech Lead cho adr/api, Tech Lead + Test Lead cho test, Tech Lead + Security cho code-review) khởi tạo checklist ban đầu dựa trên lỗi thực tế hay gặp ở các dự án trước, sau đó bổ sung dần mỗi khi AI lặp lại cùng một lỗi. Mở rộng V5.2 để phủ mọi giai đoạn AI tự sinh nội dung, không chỉ riêng BA.

3.9. rules/brd-rules.md

- Đủ cột trong bảng Yêu cầu chức năng (ID, Tính năng, Mô tả, Độ ưu tiên)?
- Yêu cầu có chung chung không (phải cụ thể, test được)?
- Yêu cầu phi chức năng đã định lượng chưa?
- Có xung đột giữa Phạm vi và Giả định không?
- Câu chữ đã ở dạng "User Action" chưa?

3.10. rules/bpm-rules.md

- Kiểm tra "nhánh cụt": mọi Gateway phải dẫn đến End Event hoặc hội tụ.
- Mỗi lane chỉ thực hiện 1 hành động của 1 Actor duy nhất.
- Tên task phải là Động từ + Danh từ.
- Mọi nhánh ra khỏi Gateway phải có nhãn điều kiện.

3.11. rules/adr-rules.md — Checklist AI tự kiểm ADR

- 1. ADR có đủ 4 phần: Context, Decision, Alternatives Considered, Consequences không?
- 2. Phần Alternatives có tối thiểu 2 phương án bị loại kèm lý do cụ thể (không chỉ ghi "không phù hợp")?
- 3. Quyết định có tuân thủ constitution.md không (VD: có vi phạm nguyên tắc Stateless Services không)?

- 4. Có mâu thuẫn với ADR nào đã tồn tại trước đó trong repo không?
- 5. Consequences có nêu rõ cả mặt tích cực và đánh đổi (trade-off), không chỉ toàn ưu điểm?

3.12. rules/api-rules.md — Checklist AI tự kiểm OpenAPI Spec

- 1. Resource naming theo danh từ số nhiều, không dùng động từ trong path (VD: /orders, không phải /getOrder)?
- 2. Có versioning rõ ràng trong path hoặc header (VD: /v1/...)?
- 3. Mọi endpoint có khai báo đầy đủ response code (200/400/401/403/404/500) kèm schema lỗi thống nhất?
- 4. Format lỗi (error response) có nhất quán toàn bộ API, đúng theo chuẩn đã định nghĩa trong constitution.md?
- 5. Trường dữ liệu nhạy cảm (PII) có được đánh dấu và loại khỏi response mặc định không?
- 6. Có mô tả (description) cho từng endpoint và từng field, không để trống?

3.13. rules/test-rules.md — Checklist AI tự kiểm Unit Test

- 1. Test có được sinh từ Acceptance Criteria (Gherkin) chứ không phải suy ngược từ code hiện tại?
- 2. Tên test theo pattern should_<kỳ vọng>_when_<điều kiện>?
- 3. Cấu trúc rõ 3 phần Arrange–Act–Assert, mỗi phần tách biệt?
- 4. Assert có kiểm tra đúng hành vi nghiệp vụ mong đợi, không chỉ kiểm tra "không lỗi" (VD: assert(result != null) là chưa đủ)?
- 5. Test có độc lập — không phụ thuộc thứ tự chạy, không gọi service/API thật?
- 6. Đã có test cho edge case (input rỗng, biên giá trị, quyền truy cập sai) chứ không chỉ happy path?

3.14. rules/testcase-rules.md — Checklist AI tự kiểm Test Case (B11)

- 1. Test Case có bám sát đúng Acceptance Criteria nguồn, không suy diễn thêm nghiệp vụ ngoài phạm vi?
- 2. Đã có đủ 3 nhóm case: positive (happy path), negative và edge case (biên giá trị, dữ liệu rỗng, sai định dạng)?
- 3. Mỗi Test Case có gắn ID tham chiếu rõ ràng tới AC nguồn (phục vụ ánh xạ RTM)?
- 4. Bước thực hiện (steps) và kết quả mong đợi (expected result) tách bạch, người khác đọc vào làm theo được ngay?
- 5. Không chứa dữ liệu cá nhân/nhạy cảm thật trong dữ liệu test mẫu — chỉ dùng dữ liệu giả lập theo data-classification.md?
- 6. Test Case có trùng lặp hoặc chồng chéo phạm vi với case khác đã được rà soát, gộp lại?

3.15. rules/code-review-rules.md — Checklist AI review tầng 1 (cụ thể hóa OWASP ASVS)

- **Input validation & Injection:**
  - Mọi input từ người dùng có được validate/sanitize trước khi dùng trong query, lệnh hệ thống, hay render HTML?
- **Authentication & Authorization:**
  - Endpoint có kiểm tra quyền truy cập đúng vai trò, không dựa vào việc ẩn đường dẫn (security by obscurity)?
- **Secrets & Cấu hình:**
  - Không có API key/mật khẩu/token hardcode trong code — bắt buộc qua Vault/Env Variables?
- **Logging:**
  - Log có tuân thủ format JSON + correlation_id theo constitution.md, không log PII?
- **Xử lý lỗi:**
  - Exception có được bắt và xử lý (Fail-Fast + log), không bị nuốt lỗi (empty catch block)?
- **Dependency:**
  - Dependency mới thêm có nằm trong danh sách được phép của CODING_CONVENTION.md, đã quét license/lỗ hổng chưa?
- **Hiệu năng:**
  - Có truy vấn N+1, vòng lặp lồng nhau không cần thiết, hay thiếu index cho query mới không?

FILE CHỈ MỤC & ĐỊNH NGHĨA CHUNG

3.16. docs-index.md — Bản đồ tài liệu dự án

Cách dựng: Tech Lead tạo sau khi toàn bộ 16 file còn lại đã có bản nháp — dùng như checklist "đã đủ chưa" trước khi ký Gate B2. Mục đích: giúp người mới và AI agent mới onboard nhanh, biết file nào đọc trước, ai là chủ sở hữu.

File	Mục đích	Owner	Tầng	Cập nhật khi nào
constitution.md	Luật kiến trúc/bảo mật/logging bất biến	Tech Lead	1 – Công ty	Khi có thay đổi kiến trúc lớn, qua PR
CODING_CONVENTION.md	Chuẩn code, naming, cấu trúc thư mục	Tech Lead	1 – Công ty	Khi đổi stack/tool format
SKILL.md	Luật vận hành AI Agent	Tech Lead	1+2	Mỗi khi đổi quy trình hoặc phạm vi dự án
tool-permissions.md	Quyền hạn hành động của AI Agent	Tech Lead	1 – Công ty	Khi thêm loại agent/tool mới
data-classification.md	Phân loại dữ liệu & quy tắc đưa vào prompt	Security Lead	1 – Công ty	Khi có loại dữ liệu mới phát sinh
ai-tool-scope.md	Danh mục AI tool duyệt riêng cho dự án	Tech Lead + Security	2 – Dự án	Khi thêm/gỡ 1 công cụ AI
prompts.md	Thư viện system prompt theo giai đoạn	BA/Tech Lead	2 – Dự án	Khi thêm giai đoạn/prompt mới
glossary.md	Từ điển thuật ngữ nghiệp vụ	BA	2 – Dự án	Liên tục từ B3 trở đi
dor-dod.md	Definition of Ready / Done cho mọi Gate	PM + Tech Lead	1 – Công ty	Khi thay đổi tiêu chí Gate
adr-template.md	Khuôn mẫu ADR	Tech Lead	1 – Công ty	Hiếm khi đổi
rules/brd-rules.md, bpm-rules.md	Linter BRD/BPMN (B3–B4)	BA	2 – Dự án	Khi phát hiện lỗi BA lặp lại
rules/adr-rules.md, api-rules.md	Linter ADR/OpenAPI (B6)	Tech Lead	2 – Dự án	Khi phát hiện lỗi kiến trúc lặp lại
rules/test-rules.md	Linter Unit Test (B9)	Tech Lead/Test Lead	2 – Dự án	Khi phát hiện test kém chất lượng lặp lại
rules/code-review-rules.md	Checklist AI review tầng 1 (B10)	Tech Lead + Security	1 – Công ty	Khi cập nhật OWASP ASVS

3.17. glossary.md — Từ điển thuật ngữ nghiệp vụ

Cách dựng: BA khởi tạo khung ở B2 với vài thuật ngữ cốt lõi đã biết trước, sau đó bổ sung liên tục trong B3 (khi phỏng vấn stakeholder) — không chờ B2 xong xuôi mới bắt đầu. Quy tắc dùng cho AI: khi sinh code (tên biến/class/API field), tài liệu hay giao tiếp, AI phải dùng đúng thuật ngữ trong bảng này; nếu gặp khái niệm chưa có, AI phải dừng lại và hỏi BA.

Thuật ngữ (VN)	Tên trong code (EN)	Định nghĩa	Từ dễ nhầm — cấm dùng thay thế
Khách hàng	Customer	[Định nghĩa cụ thể theo domain — VD: tổ chức/cá nhân ký hợp đồng mua dịch vụ]	"Client", "User" (2 khái niệm khác trong hệ thống này)

Người dùng cuối	EndUser	[Định nghĩa]	"Customer", "Account"
Đơn hàng	Order	[Định nghĩa]	"Request", "Ticket"
[Thuật ngữ khác...]	[...]	[...]	[...]

3.18. dor-dod.md — Definition of Ready / Definition of Done

Cách dựng: PM + Tech Lead định nghĩa dựa trên tiêu chí Gate đã mô tả rải rác ở mục 2 — gom lại thành 1 nguồn duy nhất để tránh mỗi người hiểu "đạt" theo cách khác nhau. Mỗi Gate trong quy trình trỏ về đúng 1 dòng tiêu chí trong bảng này.

- **DoR — Spec sẵn sàng vào Gate 1:**
  - Mọi User Story có Acceptance Criteria dạng Gherkin.
  - Không còn mục nào đánh dấu [CẦN LÀM RÕ].
  - Đã chạy rules/brd-rules.md và không còn lỗi mức Critical.
- **DoR — Sprint sẵn sàng bắt đầu:**
  - 100% task trong sprint backlog có estimate và AC rõ ràng.
  - Không còn task nào phụ thuộc task chưa xong ở sprint trước.
- **DoD — Code/PR sẵn sàng merge (Gate 3):**
  - Coverage ≥ 80% (100% business logic lõi); AAA pattern; assert theo AC.
  - AI review tầng 1 không còn finding mức High/Critical.
  - Ít nhất 1 human reviewer approve (2 nếu module lõi/bảo mật).
  - CI xanh toàn bộ (build, test, SAST, secret scan).
- **DoD — Release sẵn sàng Go-live (Gate 5):**
  - Xem chi tiết checklist đầy đủ tại Phụ lục 6, Phần 2.

PHỤ LỤC 4: BỘ BIỂU MẪU CHO BƯỚC B3 (INTERVIEW GUIDE, BIÊN BẢN HỌP, BRD, PROCESS FLOW, Q&A LOG)

Cập nhật V5.6: B3 có 3 tài liệu đầu ra nhưng Phụ lục 4 trước đây chỉ có mẫu BRD sơ sài — đã bổ sung đủ 3. Cập nhật V5.7: bổ sung thêm 2 mẫu còn thiếu mà lưu đồ B3 có nhắc tới nhưng chưa có biểu mẫu — Hướng dẫn phỏng vấn (dùng ở bước 1) và Q&A Log (dùng khi xử lý xung đột ý kiến) — nay Phụ lục 4 đủ 5 mẫu, khớp 1-1 với cột "Biểu mẫu sử dụng" trong bảng hướng dẫn thực hiện B3.

4.1. Hướng dẫn phỏng vấn / Interview Guide

Cách dựng: BA soạn riêng cho mỗi buổi phỏng vấn/workshop dựa trên mục tiêu cụ thể của buổi đó — không dùng chung 1 bộ câu hỏi cứng cho mọi buổi. Soạn trước khi họp, dùng làm kịch bản dẫn dắt, không đọc như văn bản.

- **Thông tin chung:**

Trường	Nội dung
Người được phỏng vấn	[Tên + vai trò]
Ngày giờ / Thời lượng dự kiến	[DD/MM/YYYY, HH:MM — dự kiến bao lâu]
Mục tiêu phỏng vấn	[VD: Làm rõ quy tắc tính phí hoàn trả đơn hàng]
Kỹ thuật áp dụng	Interview / Workshop / Observation / Prototyping (chọn 1, xem tiêu chí ở B3)

- **Câu hỏi mở đầu (làm quen, xác nhận bối cảnh chung):**
  - [VD: Anh/chị mô tả ngắn gọn công việc hằng ngày liên quan đến quy trình này?]
- **Câu hỏi chính (đi sâu vào nhu cầu nghiệp vụ):**

Câu hỏi	Mục đích hỏi	Câu trả lời (điền khi phỏng vấn)
[Câu hỏi 1]	[Muốn làm rõ điều gì]	
[Câu hỏi 2]	[Muốn làm rõ điều gì]	

- **Câu hỏi kết thúc:**
  - Xác nhận lại: "Tôi hiểu quy trình là... — đúng không?"
  - "Còn điều gì quan trọng mà chúng ta chưa nhắc tới không?"

Ghi chú: Xin phép ghi âm ngay ở đầu buổi (trước câu hỏi mở đầu), nêu rõ mục đích ghi âm là để BA tổng hợp chính xác, không dùng cho mục đích khác.

4.2. Biên bản họp / Workshop

Cách dựng: AI (Fireflies/Otter) ghi âm và tóm tắt tự động ngay sau buổi họp/workshop; BA rà soát bản tóm tắt, bổ sung phần AI bỏ sót. Quan trọng: phải tách rõ đâu là phát biểu gốc của stakeholder, đâu là AI diễn giải/tóm tắt — tránh tình trạng BA nhầm suy diễn của AI thành yêu cầu gốc của khách hàng, dẫn đến BRD sai lệch ngay từ nguồn.

- **Thông tin chung:**

Trường	Nội dung
Dự án / Module	[Tên dự án]
Ngày họp	[DD/MM/YYYY]
Người tham dự	[Danh sách + vai trò — VD: Nguyễn Văn A (PO), Trần Thị B (BA)]
Mục tiêu buổi họp	[VD: Làm rõ luồng xử lý đơn hàng hoàn trả]
Người ghi biên bản	AI (Fireflies/Otter) + BA rà soát

- **Nội dung thảo luận:**

Chủ đề	Ý kiến / Quyết định	Người phát biểu	Nguồn gốc
[Chủ đề 1]	[Nội dung]	[Tên]	Nguyên văn / AI diễn giải
[Chủ đề 2]	[Nội dung]	[Tên]	Nguyên văn / AI diễn giải

- **Action items:**

Việc cần làm	Người phụ trách	Deadline
[Việc 1]	[Tên]	[Ngày]

- **Câu hỏi mở / cần làm rõ thêm:** [Liệt kê — sẽ đưa vào mục [CẦN LÀM RÕ] của BRD nháp, hoặc Q&A Log nếu có xung đột ý kiến — xem mục 4.5]

4.3. BRD (Business Requirement Document)

Cách dựng: BA chọn kỹ thuật elicitation phù hợp theo BABOK v3 (interview, workshop, document analysis, observation, prototyping...) — không mặc định lúc nào cũng phỏng vấn. Sau khi có biên bản họp (4.2), BA dùng prompt B3 trong prompts.md để AI trích xuất yêu cầu vào mẫu dưới đây, rồi đối chiếu với rules/brd-rules.md trước khi gửi đi.

- **1. Thông tin tổng quan:**
  - Mục tiêu kinh doanh: [Vấn đề gì đang được giải quyết, giá trị kỳ vọng]
  - Đối tượng người dùng: [Persona chính, vai trò trong hệ thống]
  - Nguồn yêu cầu: [Link tới Biên bản họp 4.2 tương ứng]
- **2. Các bên liên quan (Stakeholders):** tái dùng mẫu Stakeholder Register ở Phụ lục 1, Phần 2.
- **3. Phạm vi:**
  - In-scope: [...]
  - Out-of-scope: [...]
  - Giả định & ràng buộc: [...]
- **4. Yêu cầu chức năng:**

ID	User Story	Độ ưu tiên	Nguồn	Trạng thái
FR-001	Là [vai trò], tôi muốn [hành động] để [lợi ích]	Must have	Biên bản họp #1	Đã chốt
FR-002	Là [vai trò], tôi muốn [hành động] để [lợi ích]	Should have	Biên bản họp #1	[CẦN LÀM RÕ]

Độ ưu tiên theo MoSCoW: Must have / Should have / Could have / Won't have (lần này).

- **5. Yêu cầu phi chức năng — PHẢI định lượng, không viết chung chung:**

Loại	Chỉ tiêu cụ thể	Cách đo

Hiệu năng	API response P95 < 500ms	Load test JMeter/k6 (xem Gate 4c)
Bảo mật	Không lỗ hổng Critical/High	DAST + Pentest (xem Gate 4b)
Khả năng mở rộng	Chịu tải 1000 concurrent user	Load test

- **6. Quy trình nghiệp vụ:** Luồng hiện tại (As-is) / Luồng tương lai (To-be) — xem chi tiết tại mục 4.4 Process Flow.
- **7. Thuật ngữ:** Không lặp lại định nghĩa ở đây — trỏ thẳng sang glossary.md (Phụ lục 3.16) để tránh 2 nguồn dữ liệu lệch nhau.

Hướng dẫn sử dụng cho AI (System Prompt)

"Bạn là một Business Analyst chuyên nghiệp. Tôi sẽ cung cấp [Biên bản họp/Transcript]. Hãy điền vào [Mẫu BRD]. Nếu thiếu thông tin, đánh dấu [CẦN LÀM RÕ]. Yêu cầu chức năng viết dạng 'Là [vai trò], tôi muốn [hành động] để [lợi ích]', gắn độ ưu tiên MoSCoW. Tuyệt đối không tự suy diễn tính năng ngoài phạm vi cuộc họp."

4.4. Process Flow / User Journey

Cách dựng: AI vẽ nháp dựa trên mô tả nghiệp vụ trong Biên bản họp/BRD (dùng Mermaid/draw.io + AI, hoặc mô tả dạng bảng như mẫu dưới nếu chưa cần hình trực quan ngay), tự kiểm bằng rules/bpm-rules.md (Phụ lục 3.10) trước khi trình BA. BA/stakeholder review lại trước khi chốt — đặc biệt kiểm tra không còn "nhánh cụt".

- **Ký hiệu BPMN 2.0 cần dùng (tối thiểu):**

Ký hiệu	Ý nghĩa
Pool / Lane	Ranh giới hệ thống / Actor thực hiện
Start Event (vòng tròn mảnh)	Điểm bắt đầu luồng
Task (hình chữ nhật bo góc)	Một hành động — tên PHẢI là Động từ + Danh từ
Gateway Exclusive (hình thoi có X)	Rẽ nhánh loại trừ — chỉ 1 nhánh được đi
Gateway Parallel (hình thoi có +)	Rẽ nhánh song song — tất cả nhánh đều chạy
End Event (vòng tròn đậm)	Điểm kết thúc luồng
Sequence Flow (mũi tên liền)	Thứ tự thực hiện trong cùng 1 lane
Message Flow (mũi tên đứt)	Trao đổi thông tin giữa 2 Pool khác nhau

- **Mẫu mô tả luồng dạng bảng (dùng khi chưa vẽ hình, hoặc làm nguồn cho AI vẽ hình):**

Bước	Lane / Actor	Loại	Mô tả	Điều kiện rẽ nhánh
1	Khách hàng	Start Event	Khách hàng yêu cầu hoàn trả	—
2	Hệ thống	Task	Kiểm tra điều kiện hoàn trả	—
3	Hệ thống	Gateway Exclusive	Đủ điều kiện hoàn trả?	Đủ → bước 4; Không đủ → bước 6
4	Kế toán	Task	Xử lý hoàn tiền	—
5	Hệ thống	End Event	Hoàn tất hoàn trả	—
6	Hệ thống	End Event	Từ chối yêu cầu, thông báo lý do	—

Quy tắc bắt buộc (đối chiếu rules/bpm-rules.md): mọi Gateway phải dẫn tới End Event hoặc hội tụ lại — không được để "nhánh cụt"; mỗi lane chỉ 1 actor; tên Task luôn là Động từ + Danh từ.

- **Phân biệt As-is / To-be:** lập 2 bảng riêng theo đúng mẫu trên, đánh dấu rõ tiêu đề "As-is — Luồng hiện tại" và "To-be — Luồng đề xuất"; chỉ ra cụ thể bước nào thay đổi/loại bỏ/thêm mới giữa 2 bảng.
- **User Journey Map (rút gọn cho task nhỏ, không cần BPMN đầy đủ):**

Giai đoạn	Hành động người dùng	Điểm chạm (Touchpoint)	Pain point	Cơ hội cải thiện
[Giai đoạn 1]	[Hành động]	[App/Web/ Email...]	[Khó khăn gặp phải]	[Đề xuất]

4.5. Q&A Log

Cách dựng: BA khởi tạo ngay khi phát sinh câu hỏi mở đầu tiên (có thể sớm từ B3 khi phỏng vấn/xử lý xung đột ý kiến), dùng xuyên suốt tới B5 để tổng hợp và chốt cùng lúc với Spec. Đây là nguồn chính thức duy nhất để tra lại "ai quyết định gì, khi nào" — không thay thế bằng chat rời rạc trên Slack/Teams.

ID	Câu hỏi / Vấn đề	Ý kiến các bên (nếu có xung đột)	Người quyết định	Quyết định cuối cùng	Trạng thái
Q-001	[Nội dung câu hỏi]	[Bên A nói X, Bên B nói Y — nếu có]	[PO/Sponsor]	[Quyết định]	Mở / Đã chốt

Quy tắc: BA chỉ ghi nhận, không tự chọn ý kiến bên nào đúng khi có xung đột — mục "Người quyết định" luôn là PO/Sponsor (hoặc Tech Lead nếu là xung đột kỹ thuật thuần túy), quyết định chính thức tại buổi duyệt Spec Gate 1 (B5).

PHỤ LỤC 5: BIỂU MẪU BUG REPORT (bổ sung V5.1)

Thông tin chung

Trường	Nội dung
Bug ID	[Tự sinh, VD: BUG-0142]
Dự án / Module	[Tên dự án / module]
Người báo lỗi	[Tên]
Ngày phát hiện	[DD/MM/YYYY]
Môi trường phát hiện	☐ DEV ☐ CI/TEST ☐ STAGING ☐ UAT ☐ PRODUCTION
Severity	☐ S1 ☐ S2 ☐ S3 ☐ S4 (xem bảng định nghĩa mục 3)
Priority	☐ P1 ☐ P2 ☐ P3 ☐ P4

Chi tiết lỗi

- **Steps to reproduce:** [Các bước tái hiện lỗi, đánh số thứ tự]
- **Expected result:** [Kết quả mong đợi theo Acceptance Criteria/Spec]
- **Actual result:** [Kết quả thực tế xảy ra]
- **Evidence:** [Screenshot / video / log đính kèm]
- **Liên kết Acceptance Criteria / Test Case liên quan:** [AC-xxx / TC-xxx]

Xử lý (điền bởi Triage Board / Dev)

Trường	Nội dung
Root cause (nếu đã xác định)	[Mô tả nguyên nhân gốc, AI có thể hỗ trợ phân tích log]
Người xử lý	[Tên Dev được gán]
Trạng thái	☐ New ☐ Triage ☐ Assigned ☐ In Progress ☐ Fixed ☐ Retest ☐ Closed ☐ Reopen
Ngày đóng / kết quả retest	[DD/MM/YYYY — Pass/Fail]

Tiêu chí	Kết quả	Ghi chú
Regression suite tự động xanh 100%	☐ Đạt ☐ Không đạt	
Bug Severity 1–2 đang mở = 0	☐ Đạt ☐ Không đạt	
Gate 4a — SIT/Regression (Test Lead ký)	☐ Đạt ☐ Không đạt	
Gate 4b — ATTT (Security Lead ký)	☐ Đạt ☐ Không đạt	
Gate 4c — Hiệu năng (Tech Lead xác nhận)	☐ Đạt ☐ Không đạt	
Toàn bộ kịch bản UAT đã chạy với PO/khách hàng	☐ Đạt ☐ Không đạt	

SIGN-OFF & GO/NO-GO CHECKLIST (bổ sung V5.1)

Phần 1: Biên bản UAT Sign-off (Gate 4)

Test Lead: _____ Ngày: ___/___/20___

Security Lead: _____ Ngày: ___/___/20___

Product Owner / Khách hàng: _____ Ngày: ___/___/20___

Phần 2: Checklist Go/No-Go (Gate 5 — trước Go-live)

Hạng mục	Kết quả
UAT Sign-off đã ký (Phần 1 ở trên)	☐ Đạt ☐ Không đạt
Rollback Plan đã được viết và diễn tập	☐ Đạt ☐ Không đạt
Build artifact deploy Production giống hệt build đã qua UAT (build-once-promote-many)	☐ Đạt ☐ Không đạt
Kế hoạch truyền thông người dùng / thông báo downtime (nếu có)	☐ Đạt ☐ Không đạt
Đội trực Hypercare đã sẵn sàng (lịch trực, kênh escalation)	☐ Đạt ☐ Không đạt
Giám sát/Dashboard/Alerting đã cấu hình cho hệ thống mới	☐ Đạt ☐ Không đạt

Quyết định: ☐ GO ☐ NO-GO (nêu lý do nếu No-Go và ngày dự kiến xem xét lại).

Project Manager (chủ trì họp Go/No-Go): _____ Ngày: ___/___/20___

Tech Lead: _____ Ngày: ___/___/20___

Product Owner: _____ Ngày: ___/___/20___